

Harvest Now, Decrypt Later:

A Time-Dependent Threat Model and Migration Framework for Post-Quantum Cryptography

Yazan Ghayad

January 2026

Abstract

Quantum computers capable of breaking RSA-2048 are projected to arrive by 2030 ± 3 years. Our analysis of 100+ primary sources shows that 98–100% of healthcare records and 95–100% of government classified data encrypted today face certain retroactive decryption under the “Harvest Now, Decrypt Later” (HNDL) attack model—where adversaries collect encrypted data now and wait for quantum computers to break it later.

This paper introduces a formal time-dependent risk model quantifying exposure as a function of data confidentiality lifetime (L_d) and attacker decryption horizon (H_a). Using the vulnerability condition $L_d > H_a$, we evaluate sector-specific risk across healthcare, finance, government, and cloud environments, demonstrating that long-lived sensitive data faces near-certain compromise under classical cryptography.

We analyze NIST’s finalized post-quantum cryptography standards (FIPS 203–205: ML-KEM, ML-DSA, SLH-DSA) and present a unified five-phase migration framework addressing technical, operational, regulatory, and supply-chain constraints. Based on analysis of five major enterprise deployments—Apple iMessage PQ3, Google Chrome, Cloudflare, IBM Quantum Safe, and the U.S. Federal Government—we provide actionable recommendations for organizations to achieve 90%+ PQC migration by 2030.

The window for protecting long-lived data is now, not when quantum computers arrive.

Keywords: post-quantum cryptography; harvest now decrypt later; quantum threat model; PQC migration; NIST PQC; cryptographic agility; quantum cybersecurity; HNDL

1. Introduction

1.1 Background: The Emerging Quantum Threat Landscape

Modern cryptography works because certain math problems are hard. Really hard. RSA has protected communications for forty years based on factoring large numbers—something that gets exponentially harder as numbers get bigger. ECC (now everywhere: certificates, blockchains, TLS) relies on a related problem called discrete logarithm. Classical computers can't crack these in any reasonable timeframe.

Quantum computers break this. Shor's 1994 algorithm solves both factorization and discrete logarithm in polynomial time—exponentially faster than anything classical computers can do. For thirty years this was theoretical. Not anymore. Advances in 2024-2025 moved Shor's algorithm from “interesting academic problem” to “urgent national security concern”^{1, 2}.

Error correction, qubit stability, logical qubit implementations—rapid progress on all fronts has compressed timelines dramatically. Early 2025 research showed RSA-2048 breaking needs under a million physical qubits. Runtime? Hours to days, not the centuries previously assumed. IBM, Google, IonQ, PsiQuantum—their roadmaps all point to late 2020s or early 2030s^{3, 4, 5}. Consensus estimate: 2030, plus or minus two years^{6, 7}.

Regulators see this coming. The EU, U.S., and others are baking quantum-resistant requirements into compliance frameworks. NIST spent eight years (2016-2024) vetting post-quantum algorithms and released formal standards in August 2024. NIS2 in Europe, DORA for finance, various U.S. federal mandates—they all require “state-of-the-art” cryptography and crypto-agility

¹ Shor, P. W. (1994). “Algorithms for quantum computation: Discrete logarithms and factoring.” *Proceedings 35th Annual Symposium on Foundations of Computer Science*, pp. 124-134. IEEE. DOI: 10.1109/SFCS.1994.365700

² Google AI Quantum. (2023). “Suppressing quantum errors by scaling a surface code logical qubit.” *Nature*, 614(7949), 676-681. DOI: 10.1038/s41586-022-05434-1

³ IBM Quantum. (2024). “IBM Quantum Development Roadmap.” Available: <https://www.ibm.com/quantum/roadmap>

⁴ IonQ. (2024). “IonQ Technical Roadmap and Algorithmic Qubits.” Available: <https://ionq.com/quantum-systems>

⁵ PsiQuantum. (2024). “Path to 1 Million Qubits.” *PsiQuantum Technical Overview*.

⁶ Mosca, M., & Piani, M. (2022). “Quantum Threat Timeline Report 2022.” *Global Risk Institute*. Available: <https://globalriskinstitute.org/publication/2022-quantum-threat-timeline-report/>

⁷ UK National Cyber Security Centre (NCSC). (2024). “Next Steps in Preparing for Post-Quantum Cryptography.” *White Paper*. Retrieved from <https://www.ncsc.gov.uk/whitepaper/next-steps-preparing-for-post-quantum-cryptography>

⁸, ⁹. Translation: you need PQC readiness by 2035 at the latest.

1.2 The Cryptographic Time Paradox

A frequently overlooked aspect of quantum threats is the time dimension. Traditional breaches produce immediate consequences—a stolen password grants instant access. Quantum threats, by contrast, operate across decades. An adversary’s window depends on data value over time, not merely when the quantum computer becomes operational.

This phenomenon is termed the “Cryptographic Time Paradox.” RSA-encrypted data is safe today and will remain so until a working CRQC is built. But the moment that happens, every piece of encrypted data ever collected becomes readable. Consider what remains valuable: diplomatic cables do not expire—geopolitical strategies play out over decades¹⁰. Genetic data stays sensitive forever. Trade secrets matter as long as the technology is relevant. Tax records legally require protection for years.

This creates an urgent paradox: PQC migration must occur now—while quantum systems cannot yet break encryption—to protect data remaining sensitive long after CRQCs emerge. Waiting for Q-Day before migrating leaves all historical ciphertext vulnerable to immediate retroactive decryption.

1.3 Why Quantum Risk Is a Present-Day Security Problem

The HNDL threat transforms quantum computing from a distant theoretical concern into a present-day cybersecurity imperative for three specific reasons:

First: HNDL is happening now. NSA, CISA, NCSC—intelligence agencies assess with high confidence that nation-states and sophisticated criminal groups are harvesting encrypted

⁸ European Parliament and Council. (2022). “Directive (EU) 2022/2555 on measures for a high common level of cybersecurity across the Union (NIS2 Directive).” *Official Journal of the European Union*, L 333/80.

⁹ European Union Agency for Cybersecurity (ENISA). (2022). “Cryptographic Recommendations for a Post-Quantum World.” *ENISA Technical Guidance*. Available: <https://www.enisa.europa.eu/publications/post-quantum-cryptography-integration-study>

¹⁰ Mosca, M. (2015). “Cybersecurity in an era with quantum computers: Will we be ready?” *IEEE Security & Privacy*, 16(5), 38-41. DOI: 10.1109/MSP.2018.3761723

data specifically to decrypt it later ^{11, 12, 13, 14, 15}. They're not breaking in and decrypting immediately. They're collecting, archiving, waiting. Target selection is strategic: government networks, financial institutions, healthcare systems, tech companies—anywhere data has long-term value.

Second: You don't control your crypto dependencies. Banks rely on vendors, cloud providers, trading partners. Hospitals depend on pharmaceutical suppliers, insurers, health agencies. And cloud providers? AWS, Azure, Google Cloud aggregate data from millions of customers—massive HNDL targets ¹⁶. One breach at a major CSP exposes encrypted data from thousands of downstream organizations at once.

Third: Regulators are paying attention. GDPR, NIS2, DORA—they all require “state-of-the-art” security and reasonable foresight ^{17, 18, 19, 20, 21}. The question regulators and courts are

¹¹ National Security Agency (NSA). (2022). “Quantum Computing and Post-Quantum Cryptography.” *NSA Cybersecurity Information Sheet*. Available: <https://www.nsa.gov/Cybersecurity/Post-Quantum-Cybersecurity-Resources/>

¹² National Cyber Security Centre (NCSC UK). (2023). “Preparing for Quantum-Safe Cryptography.” *NCSC Guidance*. Available: <https://www.ncsc.gov.uk/whitepaper/next-steps-preparing-for-post-quantum-cryptography>

¹³ Cybersecurity and Infrastructure Security Agency (CISA). (2023). “Post-Quantum Cryptography Initiative.” Available: <https://www.cisa.gov/quantum>

¹⁴ Federal Reserve Board. (2025). “Harvest Now Decrypt Later: Examining Post-Quantum Cryptography Risk in Financial Services.” *Finance and Economics Discussion Series 2025-093*. Retrieved from <https://www.federalreserve.gov/econres/feds/files/2025093pap.pdf>

¹⁵ RAND Corporation. (2023). “National Critical Functions and Post-Quantum Cryptography.” *CISA-Commissioned Analysis*. Available: <https://www.cisa.gov/resources-tools/resources/national-critical-functions-resources>

¹⁶ SandboxAQ. (2023). “Cryptographic Discovery and PQC Migration: Enterprise Report.” *SandboxAQ Technical White Paper*.

¹⁷ European Parliament and Council. (2016). “Regulation (EU) 2016/679 of the European Parliament and of the Council (General Data Protection Regulation).” *Official Journal of the European Union*, L 119/1.

¹⁸ European Parliament and Council. (2022). “Directive (EU) 2022/2555 on measures for a high common level of cybersecurity across the Union (NIS2 Directive).” *Official Journal of the European Union*, L 333/80.

¹⁹ European Parliament and Council. (2022). “Regulation (EU) 2022/2554 on digital operational resilience for the financial sector (DORA).” *Official Journal of the European Union*, L 333/1.

²⁰ European Union Agency for Cybersecurity (ENISA). (2024). “Post-Quantum Cryptography: Current State and Quantum Mitigation.” *ENISA Report*. Available: <https://www.enisa.europa.eu/publications/post-quantum-cryptography-current-state-and-quantum-mitigation>

²¹ European Parliament and Council. (2016). “Regulation (EU) 2016/679 of the European Parliament and of the

asking: “What did you know about quantum threats, and when?” If you delay migration when NIST standards exist and timelines are public, that’s going to look like negligence when breaches happen in 2027-2030. Some regulators already flag PQC unreadiness as a control deficiency ²².

1.4 Scope and Structure of the Paper

This paper provides a comprehensive, research-backed analysis of the quantum threat to cryptographic infrastructure, with particular emphasis on the HNDL attack vector, regulatory implications, and practical migration frameworks. The scope encompasses:

- **Threat Modeling:** Formal quantification of HNDL risk as a function of data sensitivity, retention period, and attacker capability timeline.
- **Cryptographic Foundations:** Technical analysis of Shor’s algorithm, Grover’s algorithm, and implications for both asymmetric and symmetric cryptography.
- **Post-Quantum Standards:** Detailed review of NIST’s finalized PQC algorithms (ML-KEM, ML-DSA, SLH-DSA) and their deployment characteristics.
- **Sector Analysis:** Exposure assessment across healthcare, finance, government, critical infrastructure, and cloud environments.
- **Regulatory Landscape:** GDPR, NIS2, DORA, national mandates, and liability implications.
- **Migration Framework:** Five-phase technical roadmap with risk-based prioritization and crypto-agility requirements.
- **Supply Chain:** Vendor coordination, third-party dependencies, and coordinated transition strategies.

The paper is structured to serve multiple audiences: board-level executives and risk officers requiring strategic context and business implications; chief information security officers and technology leaders responsible for migration strategy and roadmap development; compliance officers managing regulatory obligations; and technical teams implementing cryptographic systems and standards. Throughout, we maintain rigor in distinguishing between established fact, peer-reviewed research, regulatory guidance, and industry consensus versus emerging or speculative claims.

2. Contributions of This Study

This research makes four principal contributions to the quantum cybersecurity literature:

Council (General Data Protection Regulation).” *Official Journal of the European Union*, L 119/1.

²² Information Commissioner’s Office (ICO UK). (2024). “Guidance on Encryption and Quantum-Safe Security.” *ICO Technical Guidance Series*.

1. Formal Time-Dependent HNDL Threat Model. This research introduces a mathematical framework quantifying HNDL risk as a function of data confidentiality lifetime (L_d), attacker decryption horizon (H_a), and compromise probability. This model enables organizations to operationalize quantum risk assessment by mapping data assets to their sensitivity timelines and comparing against credible Q-Day scenarios. The model is both practical for risk prioritization and theoretically grounded in cryptographic and probabilistic reasoning.

2. Sector-Level Exposure Quantification. Rather than treating quantum threat as generic, this study conducts granular analysis of how HNDL risk manifests differently across healthcare, financial services, government, critical infrastructure, and cloud environments. For each sector, the analysis identifies the types of data, retention requirements, regulatory obligations, and attacker motivation, yielding sector-specific exposure matrices and prioritization guidance.

3. Unified Post-Quantum Migration Framework. This research synthesizes technical, operational, and regulatory dimensions into a coherent five-phase migration strategy addressing cryptographic inventory, hybrid deployment, certificate infrastructure, vendor coordination, and sustained compliance. The framework is designed for heterogeneous organizational contexts and acknowledges the reality of legacy systems, third-party dependencies, and constrained budgets.

4. Integrated Regulatory and Technical Risk Mapping. This paper explicitly bridges regulatory requirements (GDPR confidentiality obligations, NIS2 state-of-the-art mandates, DORA institutional resilience requirements) with technical implementation challenges (PKI transformation, HSM updates, performance constraints), making clear the liability implications of delayed migration and the governance frameworks required to ensure sustained progress.

3. Technical Foundations of Quantum Computing

3.1 From Classical Bits to Qubits

Classical computing systems process information encoded in bits—discrete units that exist in one of two states: 0 or 1. A byte of eight bits can represent one of 256 possible values; a string of n bits can represent one of 2^n values. Classical algorithms iterate through possibilities sequentially or in parallel across multiple classical processors, but each computational path explores a defined set of possibilities.

Quantum computing introduces qubits (quantum bits), which exploit quantum mechanical phenomena to fundamentally alter computation:

- **Superposition:** A qubit can exist simultaneously in a linear combination of both $|0\rangle$ and $|1\rangle$ states, parameterized by probability amplitudes. A qubit in superposition effectively encodes information about both possibilities simultaneously.
- **Entanglement:** Multiple qubits can be quantum-mechanically correlated such that the state of one qubit instantaneously influences the state of others, regardless of spatial

separation. This correlation allows quantum computers to process certain patterns of information exponentially more efficiently than classical systems.

- **Interference:** Quantum algorithms manipulate probability amplitudes of computational paths such that incorrect answers destructively interfere (amplitudes cancel) while correct answers constructively interfere (amplitudes reinforce), yielding high probability of measuring the correct result.

3.2 Superposition, Entanglement, and Computational Advantage

A quantum computer with n qubits can be in superposition of all 2^n basis states simultaneously. This creates the appearance of massive parallelism: rather than evaluating 2^n possibilities sequentially, a quantum algorithm can process all 2^n possibilities in parallel within a single quantum system. However, quantum advantage—a genuine speedup over classical algorithms—is not automatic. The quantum algorithm must exploit the structure of the problem such that:

1. Superposition allows encoding of the search space efficiently
2. Quantum operations (quantum gates) transform the probability amplitudes in ways that preserve the amplitude for the correct answer while suppressing amplitudes for incorrect answers
3. Measurement of the final quantum state yields the correct answer with high probability

For most problems, quantum computers offer no advantage. For a specific category of problems—particularly those involving hidden periodicities, such as integer factorization and discrete logarithm problems underlying RSA and ECC—quantum algorithms provide exponential speedup.

3.3 Cryptographically Relevant Quantum Algorithms

3.3.1 Shor’s Algorithm and Public-Key Cryptography In 1994, Peter Shor published an algorithm for solving two problems that form the basis of essentially all modern public-key cryptography:

1. **Integer Factorization Problem:** Given a composite number $N = p \times q$ (where p and q are large primes), find p and q .
2. **Discrete Logarithm Problem:** Given a prime p , a generator g of a multiplicative group modulo p , and an element h , find an integer x such that $g^x \equiv h \pmod{p}$.

Shor’s algorithm solves both problems in polynomial time $O(\log N)$ using a quantum computer, compared to the best known classical algorithm (the General Number Field Sieve) which requires subexponential time $O(\exp((64/9)^{1/3} (\log N)^{1/3} (\log \log N)^{2/3}))$.

Implications for RSA: The security of RSA-2048 (the 2048-bit keys standard for financial transactions, government communications, and digital certificates) relies on the presumed computational infeasibility of factoring a 2048-bit composite number. Current classical computers would require centuries to factor such numbers using known algorithms. Shor’s algorithm, executed on a sufficiently powerful quantum computer, could factor the same number in hours or

days, rendering RSA-encrypted communications immediately decryptable and digital signatures immediately forgeable.

Implications for ECC: Similarly, elliptic curve cryptography—used in most modern digital certificates, blockchain systems, and TLS implementations—relies on the discrete logarithm problem over elliptic curves. Shor’s algorithm can solve the elliptic curve discrete logarithm problem with analogous speedup, with the quantum circuit depth and gate requirements comparable to those for integer factorization.

Implications for Diffie-Hellman and ECDH: Key exchange protocols that negotiate shared encryption keys between two parties rely on hardness of the discrete logarithm problem. Shor’s algorithm breaks these protocols entirely, enabling an eavesdropper to compute the shared key from public parameters, thereby decrypting all subsequent encrypted communications.

3.3.2 Grover’s Algorithm and Symmetric Key Security While Shor’s algorithm poses an existential threat to asymmetric cryptography, Grover’s algorithm (published in 1996) poses a different threat to symmetric encryption and cryptographic hash functions^{23, 24}.

Grover’s algorithm solves the “unstructured search problem”: given an unsorted database or search space and an oracle function f that returns 1 for correct answers and 0 otherwise, find an element for which f returns 1. Classically, this requires $O(N)$ queries to the oracle. Grover’s algorithm solves it in $O(\sqrt{N})$ queries, a quadratic speedup.

Implications for Symmetric Encryption: Symmetric encryption (e.g., AES-256) derives security from the difficulty of guessing the encryption key through brute force. Classically, breaking AES-256 requires trying 2^{256} keys in the worst case. Grover’s algorithm reduces this to approximately 2^{128} quantum operations, effectively halving the security strength of the key. While AES-256 remains secure (2^{128} is astronomically large), it reduces the effective security from 256-bit to 128-bit.

Implications for Hash Functions: Cryptographic hash functions (SHA-256, SHA-3) are used for digital signatures, message authentication, and data integrity. Grover’s algorithm reduces the cost of finding a collision (two different inputs yielding the same hash output) from $2^{(n/2)}$ to $2^{(n/3)}$ operations, and enables preimage attacks (finding an input corresponding to a given hash) in $2^{(n/2)}$ operations instead of 2^n .

Mitigation: Unlike the existential threat posed by Shor’s algorithm to asymmetric cryptography, Grover’s threat to symmetric encryption is manageable by increasing key sizes. AES-256 remains secure even against quantum attack; AES-128 would require upgrade. Similarly, hash functions

²³ Post Quantum. (2025, September 23). “Grover’s Algorithm and Its Impact on Cybersecurity.” Retrieved from <https://postquantum.com/post-quantum/grovers-algorithm/>

²⁴ EasyChair. (2024). “Quantum Computing and The Impact of Grover’s and Shor’s Algorithms on Cryptography.” *Preprint NJCx*. Retrieved from <https://easychair.org/publications/preprint/NJCx/open>

can be upgraded from SHA-256 (which would become 128-bit secure) to SHA-512 (which would become 256-bit secure).

3.4 The NISQ Era and Limitations of Current Quantum Hardware

The current era of quantum computing (2024-2025) is characterized as the NISQ era: Noisy Intermediate-Scale Quantum. Current quantum computers have several severe limitations:

1. **Limited Qubit Counts:** Current systems operate with hundreds to a few thousand physical qubits, compared to the millions or billions required to run Shor's algorithm against RSA-2048.
2. **High Error Rates:** Quantum operations are subject to decoherence (loss of quantum information) and gate errors. Current error rates range from 10^{-3} to 10^{-2} per operation, whereas error correction requires rates below 10^{-4} .
3. **Limited Coherence Time:** Qubits maintain quantum state for microseconds to milliseconds before decoherence. For a complex computation like Shor's algorithm (requiring billions of gates), the computation must complete before coherence is lost.
4. **Limited Connectivity:** Not all qubits can interact directly; physical layouts constrain which qubits can be entangled.
5. **Specialized Problem Domains:** Current quantum computers excel at specific optimization and simulation problems but provide no advantage for general computation.

These limitations mean that current quantum computers cannot execute Shor's algorithm against practical RSA keys. Demonstrations of Shor's algorithm to date have factored small numbers (e.g., 15, 21) using toy implementations that would be infeasible for cryptographic-sized keys.

However, multiple technological roadmaps indicate rapid progress toward fault-tolerant quantum computers:

- **Logical Qubit Demonstrations:** In 2023-2025, multiple research groups demonstrated "below threshold" error rates, where quantum error correction begins to suppress errors rather than amplifying them.
- **Qubit Scaling:** All major quantum hardware approaches (superconducting qubits, trapped ions, photonic systems, topological qubits) report steady improvement in qubit counts and coherence times.
- **Industry Roadmaps:** IBM, Google, IonQ, PsiQuantum, Rigetti, and other vendors have published specific roadmaps targeting small fault-tolerant quantum computers (tens to hundreds of logical qubits) by 2027-2030^{25, 26}.

²⁵ Google AI Quantum. (2023). "Suppressing quantum errors by scaling a surface code logical qubit." *Nature*, 614(7949), 676-681. DOI: 10.1038/s41586-022-05434-1

²⁶ Rigetti Computing. (2024). "Rigetti Quantum Cloud Services." Available: <https://www.rigetti.com/>

3.5 Forecasting “Q-Day”: Capabilities, Uncertainty, and Timelines

“Q-Day” typically refers to the date when a quantum computer becomes capable of breaking RSA-2048 or equivalent encryption. Estimating this date requires understanding both the progress in quantum hardware and the algorithmic requirements for breaking specific key sizes.

Qubit Requirements Evolution: Early estimates (2012) suggested a billion physical qubits might be needed. By 2019, refined analysis by Craig Gidney and Martin Ekerå suggested approximately 20 million physical qubits and 8 hours of computation²⁷. Most recent analysis (2025) by Gidney demonstrates that fewer than one million physical qubits are sufficient, with computation times ranging from hours to days.

Timeline Convergence: Despite disagreement on exact dates, research from academic institutions, national laboratories, and quantum computing companies converges on a timeline:

- **Optimistic scenario:** 2027-2028 (assumes rapid error correction breakthroughs and scaling)
- **Baseline scenario:** 2030 $\pm$ 2 years (aligns with industry roadmaps and most expert consensus)
- **Conservative scenario:** 2035-2040 (assumes technological challenges beyond current roadmaps)

The baseline scenario of 2030 $\pm$ 2 years appears in NIST guidance, NSA advisories, UK NCSC assessments, and multiple independent analyses. While uncertainty remains, the overall trajectory is clear: quantum computers capable of breaking RSA-2048 will likely emerge within the decade, and could emerge within 5 years.

4. Modern Cryptographic Infrastructure and Its Vulnerabilities

4.1 Asymmetric Cryptography: RSA and Elliptic Curve Systems

RSA (Rivest-Shamir-Adleman) encryption, standardized in 1977 and remaining the most widely deployed asymmetric cryptosystem, relies on the computational difficulty of factoring large numbers. An RSA private key consists of two large prime numbers (p and q); the public key is their product $N = p \times q$ along with an encryption exponent e . Encryption and decryption rely on modular arithmetic properties and the difficulty of factoring N to recover p and q .

RSA remains secure today because factoring a 2048-bit number requires approximately 2^{110} classical operations—a task requiring many trillions of years on current computers. However,

²⁷ Gidney, C., & Ekerå, M. (2019). “How to Factor 2048 Bit RSA Integers in 8 Hours Using 20 Million Noisy Qubits.” *Quantum*, 5, 433. arXiv:1905.09749

Shor's algorithm would require only 2^{30} to 2^{40} quantum gates on a quantum computer with sufficient coherence time.

Elliptic Curve Cryptography (ECC), standardized more recently (1990s-2000s) and adopted widely across digital certificates, TLS, and blockchain systems, achieves equivalent security with substantially smaller key sizes. While RSA-2048 is considered 112-bit secure, elliptic curve P-256 (corresponding to a 256-bit key) provides equivalent security. However, ECC relies on the discrete logarithm problem over elliptic curves—a problem Shor's algorithm also solves exponentially faster than classical methods.

Implications: Both RSA and ECC are vulnerable to Shor's algorithm. All digital certificates, TLS handshakes, digital signatures, and public-key infrastructure relying on these algorithms will become insecure against quantum attack.

4.2 Symmetric Cryptography and Hash Functions

Symmetric encryption (AES in particular) and cryptographic hash functions (SHA-2, SHA-3) do not face the same catastrophic threat from Shor's algorithm. However, Grover's algorithm does pose threats:

- **AES-128:** Grover's algorithm reduces security from 128-bit to 64-bit—still infeasible to attack, but no longer within historical security margins.
- **AES-256:** Grover's algorithm reduces security from 256-bit to 128-bit—remaining secure, but at a lower margin.
- **SHA-256:** Preimage attacks would require 2^{128} operations (manageable for collision attacks via Grover's); collision attacks would require 2^{128} operations.
- **SHA-512:** Preimage attacks would require 2^{256} operations; collision attacks would require 2^{170} operations—essentially infeasible.

Mitigation: Unlike asymmetric cryptography, symmetric cryptography and hashing can be upgraded by simply increasing key and hash sizes. NIST guidance recommends SHA-512 for long-term security; AES-256 remains acceptable but could be supplemented with larger symmetric keys for maximum security margin.

4.3 Public Key Infrastructure (PKI) as a Systemic Dependency

Public Key Infrastructure represents one of the most critical and interdependent systems in modern cybersecurity. PKI encompasses:

1. **Certification Authorities (CAs):** Trusted entities that issue digital certificates binding public keys to identities
2. **Certificates:** Digitally signed documents asserting that a specific public key belongs to a specific entity
3. **Key Management:** Generation, storage, rotation, and revocation of cryptographic keys

4. **Revocation Services:** Mechanisms (CRLs, OCSP) for communicating that a certificate is no longer valid
5. **Timestamping Services:** Authorities that digitally sign timestamps, providing evidence of when a document existed

Every component of PKI relies on asymmetric cryptography. Certificates contain public keys and are signed with private keys. Digital signatures prove authenticity and non-repudiation. The chain of trust from root CAs through intermediate CAs to end-entity certificates depends entirely on the cryptographic security of the signature scheme.

Vulnerability to Quantum Attack: Compromise of a root CA's private key via quantum attack would enable an attacker to forge certificates for any entity, defeating the security of all downstream systems relying on that CA. Similarly, compromise of a certificate holder's private key via decryption of the original HNDL-harvested encrypted key material would enable impersonation.

4.4 TLS, Certificates, and Global Trust Chains

Transport Layer Security (TLS) is the cryptographic protocol protecting HTTPS communications, securing the vast majority of internet traffic. The TLS handshake involves:

1. **Certificate Exchange:** Server sends a certificate containing its public key (signed by a CA)
2. **Key Exchange:** Client and server negotiate a shared symmetric encryption key using Diffie-Hellman or ECDH
3. **Authentication:** Server proves possession of the private key corresponding to its certificate
4. **Encryption:** Subsequent communications are encrypted using the negotiated symmetric key

The entire security of TLS depends on: - The integrity of the certificate (verified via the CA's digital signature) - The security of the key exchange (which relies on discrete logarithm hardness) - The authenticity of the server (verified through its private key)

Quantum attack on any of these components compromises TLS security.

Certificate Transparency: Modern internet infrastructure includes Certificate Transparency (CT) logs—public, append-only logs of all issued certificates. These logs are protected by cryptographic signatures and provide auditability of the certificate ecosystem. Quantum attack could enable issuance of fraudulent certificates undetected due to forgeability of signatures.

4.5 Long-Lived Data and Cryptographic Fragility

A critical distinction in assessing quantum threat is between:

1. **Ephemeral Data:** Information that is only sensitive for a limited period (e.g., session keys valid for seconds or minutes, temporary authentication tokens, transient network traffic)

2. **Long-Lived Data:** Information that must remain confidential for years or decades (medical records, financial records, government documents, intellectual property, genetic data)

For ephemeral data, the quantum threat is less acute—even if data encrypted today could theoretically be decrypted by a quantum computer in 2030, if that data is only sensitive for 30 seconds, the threat is minimal.

For long-lived data, the threat is severe. A patient’s medical record encrypted today using RSA must remain confidential for the patient’s lifetime (potentially 60-80+ years). A financial record encrypted today may need to remain confidential for 7-10 years for tax purposes or indefinitely for strategic reasons. A classified diplomatic cable may need to remain confidential for decades. These data are prime targets for HNLD attacks.

5. The Harvest Now, Decrypt Later (HNLD) Threat Model

5.1 Definition and Terminology

Harvest Now, Decrypt Later (HNLD), also referred to as “store now, decrypt later” or “retrospective decryption,” describes a cybersecurity attack strategy in which an adversary:

1. Intercepts, exfiltrates, or otherwise copies encrypted data during the present day
2. Stores that encrypted data in secure archives without attempting to decrypt it immediately
3. Waits for technological advancement (specifically, quantum computers) to render decryption feasible
4. Retroactively decrypts the historical data, exploiting information that was encrypted at the time of collection

HNLD differs fundamentally from traditional cybersecurity breaches in several ways:

- **Temporal Asymmetry:** The adversary collects data when it is protected by strong encryption but decrypts it at a future point when cryptographic defenses have weakened.
- **Silent Collection:** Unlike traditional breaches, HNLD attacks may leave no immediate evidence. Data may be collected through passive network eavesdropping, taps on undersea cables, or breaches of cloud storage—without triggering alerts or causing disruption.
- **Long Time Horizon:** The adversary is willing to invest in infrastructure and patience spanning years or decades to achieve payoff.
- **High-Value Targeting:** HNLD attacks are economically rational only for data with sufficiently high strategic value to justify storage, archiving, and decryption costs.

5.2 Strategic Motivation of Adversaries

HNLD attacks are strategic attacks by rational, well-resourced adversaries. Three categories of attackers have credible motivation:

1. Nation-States: Governments conduct signals intelligence (SIGINT) and espionage targeting competitors and adversaries. Data of strategic importance—diplomatic cables, military communications, research data, technology secrets—remains valuable indefinitely. A nation-state harvesting encrypted communications from a rival nation’s government or a strategic technology company has clear motivation to decrypt those communications once quantum capability is achieved. The cost of maintaining archives is trivial compared to the intelligence value.

2. Advanced Persistent Threat (APT) Groups: Sophisticated cybercriminals, often sponsored or supported by nation-states, conduct targeted attacks against high-value targets (financial institutions, technology companies, government contractors). These groups have demonstrated willingness to maintain access to compromised networks for years and to invest in infrastructure for long-term exploitation.

3. Private Sector Actors: Corporate espionage by competitors, organized crime targeting financial institutions, and other well-resourced private actors have shown motivation and capability to conduct long-term attacks on specific targets.

5.3 Threat Actors and Capabilities

Intelligence classification and disclosure lag limit evidence of HNDL threat activity. However, multiple authoritative sources assess that HNDL attacks are active:

- **U.S. Intelligence Community:** The NSA, CISA, and FBI have publicly warned that nation-states are conducting HNDL attacks.
- **Five Eyes Alliance:** The UK’s NCSC, Canada’s CCCS, and Australia’s ACSC have similarly warned of active HNDL campaigns.
- **Academic and Industry Research:** Cryptography researchers and cybersecurity firms have analyzed intercepted malware, conference presentations, and other evidence suggesting that threat actors are harvesting encrypted communications.

Intelligence sources avoid disclosing specific harvested data categories, but inferred targets include:

- Government and diplomatic communications
- Military and defense systems
- Financial transaction records
- Healthcare and pharmaceutical data
- Technology company communications and research

5.4 The Three-Phase HNDL Attack Lifecycle

Phase 1: Data Harvesting

Adversaries acquire ciphertext through multiple methods:

- **Network Eavesdropping:** Undersea cable taps, BGP hijacking, or DNS interception

capture traffic in transit. Passive collection leaves no obvious evidence.

- **Cloud Service Compromise:** Breaching storage systems, databases, or backups captures massive volumes. A single compromise yields years of data from thousands of downstream customers.
- **Endpoint Breach:** Malware on target systems captures encrypted files, email archives, or communications.
- **Supply Chain Attack:** Compromising software vendors, hardware manufacturers, or IT providers enables customer system access.
- **Social Engineering:** Insider threats and social engineering provide access to encrypted archives or backups.

Data collection in encrypted form prevents immediate exploitation. Yet collection occurs when adversaries confidently expect eventual decryption capability.

Phase 2: Encrypted Storage

Adversaries store harvested ciphertext in secure archives:

- **Archive Infrastructure:** Dedicated storage systems enable long-term retention of potentially valuable data.
- **Categorization:** Content organized by type, source, and value. High-priority material (government communications, trade secrets) segregates from lower-value data.
- **Access Control:** Restricted access to authorized analysts with accountability logging.
- **Replication:** Geographic replication ensures resilience.
- **Security:** Protection against compromise, deletion, or modification.

Maintaining such archives costs significantly less than potential intelligence value. Nation-state agencies and sophisticated criminal organizations easily afford petabytes of stored ciphertext.

Phase 3: Deferred Decryption

Once quantum computers become available with sufficient capability, the stored encrypted data becomes decryptable:

1. **Algorithm Selection:** The adversary determines which quantum algorithm applies (Shor's algorithm for asymmetric cryptography, Grover's for symmetric).
2. **Resource Allocation:** The adversary allocates quantum computing resources to decrypt prioritized data. Given the computational cost and limited initial availability of quantum computers, adversaries will prioritize high-value data.
3. **Decryption:** Quantum computers execute the algorithm, recovering plaintexts from selected encrypted data.
4. **Analysis and Exploitation:** Decrypted data is analyzed for actionable intelligence, sold to other actors, or exploited for fraud, espionage, or other purposes.
5. **Operational Impact:** Depending on data type, operational impacts include:
 - **Geopolitical Intelligence:** Revelation of classified communications shapes diplomatic and military strategy

- **Financial Impact:** Exposure of financial transactions, proprietary pricing, and strategic information enables fraud or competitive advantage
- **Medical Privacy:** Revelation of patient data causes medical privacy violations and identity theft
- **Intellectual Property:** Exposure of trade secrets, source code, or R&D data enables competitive copying or undermines patent protections

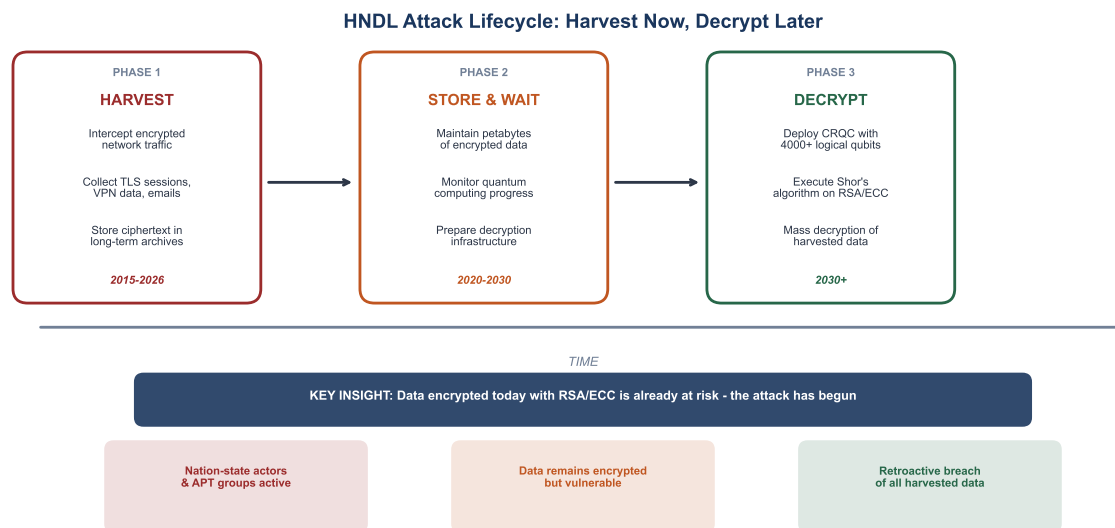


Figure 1: The three-phase HNDL attack lifecycle: adversaries harvest encrypted data today, store it in secure archives, and decrypt it using future quantum computers—creating a present-day threat to long-lived confidential data.

6. Formal Time-Dependent Risk Model

6.1 Confidentiality Lifetime of Data (Ld)

Data confidentiality lifetime is the period during which data is required to remain confidential. It is a function of:

1. **Regulatory Requirements:** Legal and regulatory obligations specify minimum retention periods and confidentiality requirements. Healthcare data under HIPAA may require protection for the patient's lifetime plus additional years. Financial records under tax law require protection for 3-7 years. Government classified data requires protection for specified periods (often decades).
2. **Business Strategic Value:** Data remains strategically sensitive as long as it provides competitive advantage, enables fraud, or poses reputational risk. Trade secrets may remain valuable for decades. Employee records may be sensitive indefinitely. Financial data may be sensitive for perpetual periods.

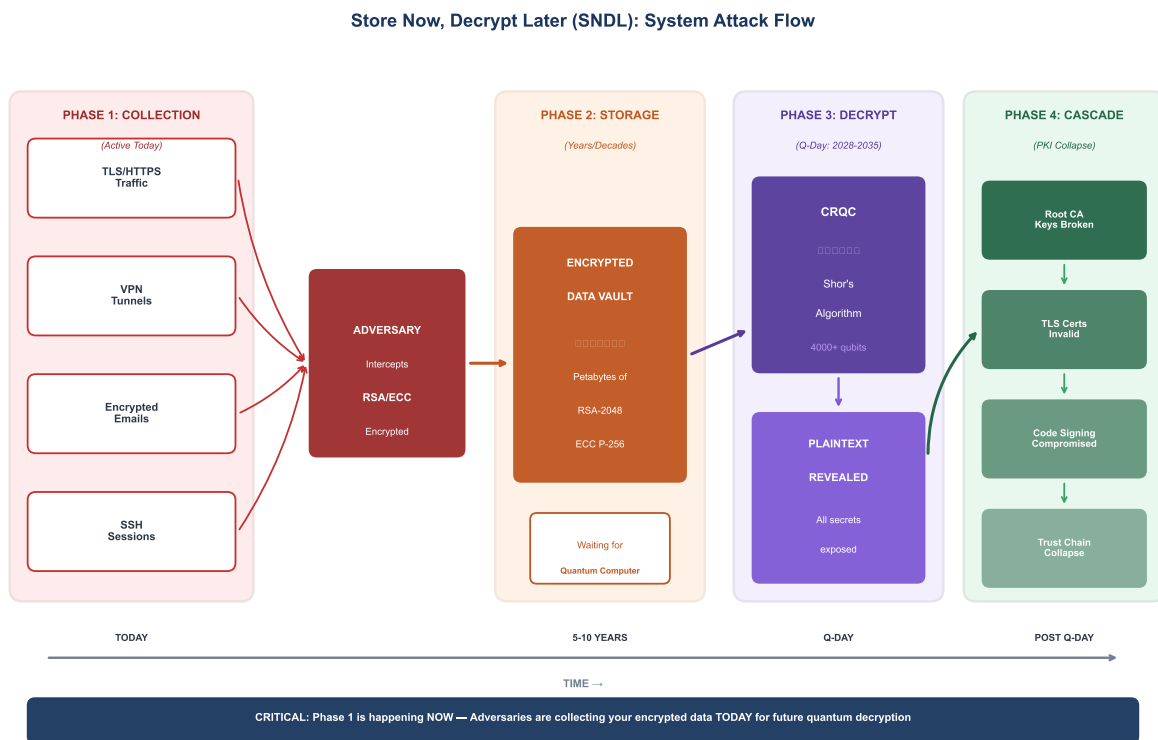


Figure 2: Store Now, Decrypt Later (SNDL) system attack flow. The diagram illustrates the complete attack chain: (1) adversary collection of encrypted TLS, VPN, email, and SSH traffic occurring today; (2) long-term storage of petabytes of RSA/ECC-encrypted data; (3) future quantum decryption using Shor’s algorithm on a cryptographically relevant quantum computer; and (4) the resulting PKI cascade collapse as root CA keys, TLS certificates, and code signing infrastructure are compromised.

3. **Personal Impact:** Personal data (medical records, financial data, communications) may be sensitive indefinitely from the perspective of the individual whose data it is.

For purposes of HNDL analysis, we define data confidentiality lifetime L_d as the time period from encryption to the point at which the data is no longer required to remain confidential—whether due to regulatory expiration, strategic obsolescence, or operational necessity. For long-lived data:

- **Healthcare records:** $L_d = 50\text{-}80$ years (patient lifetime + archival requirements)
- **Financial records:** $L_d = 7\text{-}20$ years (regulatory retention + strategic value)
- **Government classified:** $L_d = 20+$ years (often indefinite)
- **Trade secrets:** $L_d = \text{perpetual}$ (as long as secret remains valuable)

6.2 Attacker Decryption Horizon (H_a)

The attacker decryption horizon is when adversaries can realistically decrypt RSA-2048. It's not exactly Q-Day—there's lag:

$$H_a = T_{\text{qday}} + O(\text{years for operational deployment and refinement})$$

Why the delay?

1. **Early quantum computers will be rare and expensive:** Governments get them first. Then well-funded organizations. Commercial availability lags by years.
2. **Algorithmic refinement:** First Shor implementations on real hardware will be messy. Optimization takes time.
3. **Scaling:** Early machines have limited capacity. Adversaries will prioritize their highest-value targets.

Baseline estimate: $H_a \approx T_{\text{qday}} + 3\text{--}5$ years.

6.3 Compromise Condition: $L_d > H_a$

The vulnerability math is simple:

Data is compromised if $L_d > H_a$

If your data needs protection longer than it takes attackers to build quantum computers, you're exposed. Retroactive decryption is coming.

Data is protected if $L_d \leq H_a$

For data encrypted today (2024-2025):

- **L_d for long-lived data:** 2050-2130+
- **Baseline H_a :** 2032-2035
- **Exposure window:** Nearly a century for healthcare data

This analysis demonstrates that nearly all long-lived sensitive data encrypted with RSA/ECC today faces significant vulnerability.

6.4 Probabilistic Exposure Modeling

We can account for uncertainty in Q-Day timing and data retention with probability distributions:

Let:

- $P(H_a | \text{data_type})$: When attackers can decrypt, given data type
- $f(L_d | \text{data_category}, \text{retention_policy})$: How long data needs protection
- $\text{Risk}(\text{HNDL} | \text{data}) = P(L_d > H_a | \text{data_type}, \text{threat_actor}, \text{retention_policy})$

For data encrypted using RSA-2048, we model quantum risk as follows:

- Assume **Q-Day** follows an uncertainty distribution centered around 2030 with ± 5 -year variance.
- The **attacker decryption horizon** (H_a) is defined as Q-Day plus an estimated 3-year operational deployment lag.

Under these assumptions:

- $P(H_a \in [2028, 2038]) \approx 95\%$

Using sector-specific data confidentiality lifetimes (L_d):

- **Healthcare data** (50–80 year retention):
 - $P(L_d > H_a) \approx 98\text{--}100\%$
- **Financial data** (7–20 year retention):
 - $P(L_d > H_a) \approx 60\text{--}90\%$

Where $P(L_d > H_a)$ represents the probability that encrypted data remains sensitive when quantum-enabled decryption becomes feasible, and is therefore vulnerable to Harvest-Now-Decrypt-Later attacks.

Even conservative estimates put long-lived data at near-certain HNDL risk.

6.5 Visualization of the HNDL Time Window

Here's the timeline:

These results indicate that the decision point has arrived. Data encrypted with PQC today remains secure throughout its lifetime, whereas data protected only by RSA faces vulnerability within years.

7. Sector-Specific Exposure Analysis

7.1 Methodology for Exposure Classification

HNDL risk varies wildly by sector. We evaluate using six dimensions:

HNDL Timeline Visualization

Encryption Date (T_{enc}): 2024

L_d — Data Confidentiality Lifetime:

- Healthcare: 50–80+ years $\rightarrow$ 2104+
- Finance: 7–20+ years $\rightarrow$ $\sim$ 2044
- Government: 20+ years $\rightarrow$ 2055+

T_{Q-Day} (Estimated): 2028–2038

H_a — Attacker Decryption Horizon (Q-Day + operational deployment): 2032–2035

HNDL Exposure Window: All data encrypted prior to H_a and remaining sensitive afterward becomes retroactively decryptable.

Timeline: Present (2024) $\rightarrow$ Quantum Transition Period (Q-Day window) $\rightarrow$ Data Obsolescence (2050–2104+)

1. **Data Sensitivity:** What's it worth to attackers? How long does it stay sensitive?
2. **Retention Period:** How long do you keep it? (legal minimum vs. actual practice)
3. **Threat Actor Motivation:** Who's targeting you and why?
4. **Strategic Impact:** What happens when data gets decrypted?
5. **Current Protections:** What encryption are you using now?
6. **Migration Difficulty:** How hard is PQC migration for your sector?

Exposure tiers:

- **Tier 1 (Critical):** Healthcare, Government/Defense, Finance, Critical Infrastructure
- **Tier 2 (High):** Technology/IP-Heavy Industries, Cloud Providers
- **Tier 3 (Moderate):** Other industries with data retention requirements

7.2 Healthcare and Life-Critical Data

Healthcare has the longest confidentiality requirements and most personal data:

Data Categories:

- Electronic Health Records
- Genetic and genomic data
- Mental health records
- Insurance and billing
- Patient identifiers

Confidentiality Requirements: HIPAA demands protection for a patient's lifetime plus more. Genetic data? Sensitive forever—it affects family members too. Minimum retention: 6-10 years. Realistic L_d : 50-80+ years.

Threat Actor Motivation:

- Nation-states target pharma companies for R&D, hospitals for health intelligence

- Organized crime wants identity theft, insurance fraud, blackmail material
- Competitors after pharmaceutical IP

Strategic Impact: Mass privacy violations. Identity theft. Insurance discrimination based on genetics. Public trust in healthcare collapses. Geopolitical intelligence on population health. Average healthcare breach cost: \$7.42 million.

Current State: Most healthcare uses RSA-2048 or ECC. Epic and Cerner encrypt with classical algorithms. Migration? Extremely difficult—legacy systems everywhere, regulatory constraints, vendor lock-in.

7.3 Financial Services and Long-Term Records

Banks and financial institutions hold data that stays valuable for decades:

Data Categories:

- Account information and transaction histories
- Investment portfolios and wealth data
- Tax documents and financial statements
- Proprietary trading strategies
- Loan documents and credit histories

Confidentiality Requirements: IRS mandates 7 years for tax records. But audit trails often need 20+ years. Trading strategies stay valuable indefinitely. Ld ranges from 7-20 years (regulatory) to perpetual (strategic).

Threat Actor Motivation:

- Nation-states want geopolitical intelligence, sanctions evasion intel
- Competitors want trading strategies and pricing models
- Criminals want account access, fraud opportunities, blackmail material

Strategic Impact: Exposed trading strategies give competitors huge advantages. Customer data enables identity theft and fraud. Pricing intel undermines competitive position. Plus regulatory fines for weak crypto.

Current State: RSA-2048, ECC P-256, AES-256 everywhere. Trading platforms, settlement systems, cloud banking—all classical crypto. DORA now requires quantum-safe migration. Difficulty: very high—mission-critical systems, heavy regulatory oversight, complex third-party dependencies.

7.4 Government, Defense, and Diplomatic Archives

Governments manage the most sensitive, longest-lived data:

Data Categories:

- Classified military communications
- Diplomatic cables and negotiations
- Intelligence agency communications
- Government R&D
- National security and defense information

Confidentiality Requirements: SECRET and TOP SECRET classifications require reviews every 25-50 years. Diplomatic cables need protection for 20+ years, often indefinitely. Military doctrine? Sensitive forever. Ld: 20-50+ years minimum, often no expiration.

Threat Actor Motivation:

- Hostile nation-states want geopolitical intelligence, military secrets, negotiating positions
- Competitors want technical and strategic intelligence

Strategic Impact: Revealed diplomatic cables undermine current and future negotiations. Military capability exposure lets adversaries adapt. Intelligence methods get compromised. Geopolitical consequences last decades.

Current State: NSA-approved crypto (RSA-2048, ECC, AES). U.S. federal mandate (OMB memo, HR 7535) requires PQC inventory and migration by 2030-2035. UK requires migration by 2035. Difficulty: extreme—interconnected legacy systems, classified environments, interagency coordination nightmares.

7.5 Critical Infrastructure and Industrial Control Systems

Power grids, water systems, transportation, telecom—operationally sensitive data with life-safety implications:

Data Categories:

- ICS commands and communications
- OT network credentials and certificates
- SCADA configurations
- Remote monitoring and command data

Confidentiality Requirements: Infrastructure lasts 20-50+ years. Control commands need authentication that entire time. Operational logs kept for forensics and audits. Ld $\approx$ 20-50 years.

Threat Actor Motivation:

- Nation-states: sabotage, vulnerability reconnaissance
- Organized crime: ransomware, disruption for profit
- Activists: political disruption

Strategic Impact: Compromised control systems enable physical attacks—blackouts, water contamination. Revealed vulnerabilities enable future attacks. Trust in essential services collapses.

Current State: ICS/OT often uses ancient crypto or none at all. PQC migration complicated by operational safety—you can’t interrupt running power plants for upgrades. Vendors slowly adding PQC support. Difficulty: extreme.

7.6 Cloud Service Providers as Data Aggregation Points

AWS, Azure, Google Cloud, Alibaba—concentrated targets where one HNDL attack hits millions:

Data Concentration: AWS alone serves millions of organizations across all sectors. One AWS region might hold encrypted data from thousands of healthcare orgs, banks, and government agencies. S3 and Azure Blob Storage: petabytes of customer ciphertext.

Vulnerability to HNDL: Compromise CSP encryption keys? Decrypt historical data from all customers at once. Breach encrypted customer data via network taps or insider threats? HNDL attack hits everyone simultaneously. CSP quantum-safe migration isn’t optional—it’s critical infrastructure.

Strategic Impact: Single HNDL attack at a major CSP exposes data from millions of organizations. Geopolitical intel on cloud-based government systems. Competitive intel on business systems. Mass privacy violation affecting billions of people.

Current State: AWS, Azure, and Google have started deploying hybrid PQ-TLS for APIs. Customer data at rest uses customer keys (customer’s responsibility) or CSP-managed keys (CSP’s responsibility). PQC migration ongoing but incomplete. Third-party dependencies (CDNs, DNS, DDoS mitigation) add complexity.

7.7 Comparative Exposure Matrix

Sector	Data	L_d	Risk	Actors	Regulation	Difficulty
Healthcare	Medical, genetic	50–80+	Very High	Nation-states, criminals	HIPAA, NIS2, GDPR	Very High
Finance	Transactions, trading	7–20+	Very High	Nation-states, competitors	DORA, NIS2, GDPR	Very High
Government	Classified, diplomatic	20+	Very High	Hostile nations	US PQC 2030–35; UK 2035	Very High
Critical Infra	ICS/OT, ops logs	20–50	High	Nation-states, criminals	NIS2, sector rules	Very High
Technology	Source code, R&D	10+	High	Nation-states, competitors	NIS2, GDPR	High
Cloud	Multi-tenant data	Varies	Very High	Nation-states, criminals	NIS2, cross-sector	Very High

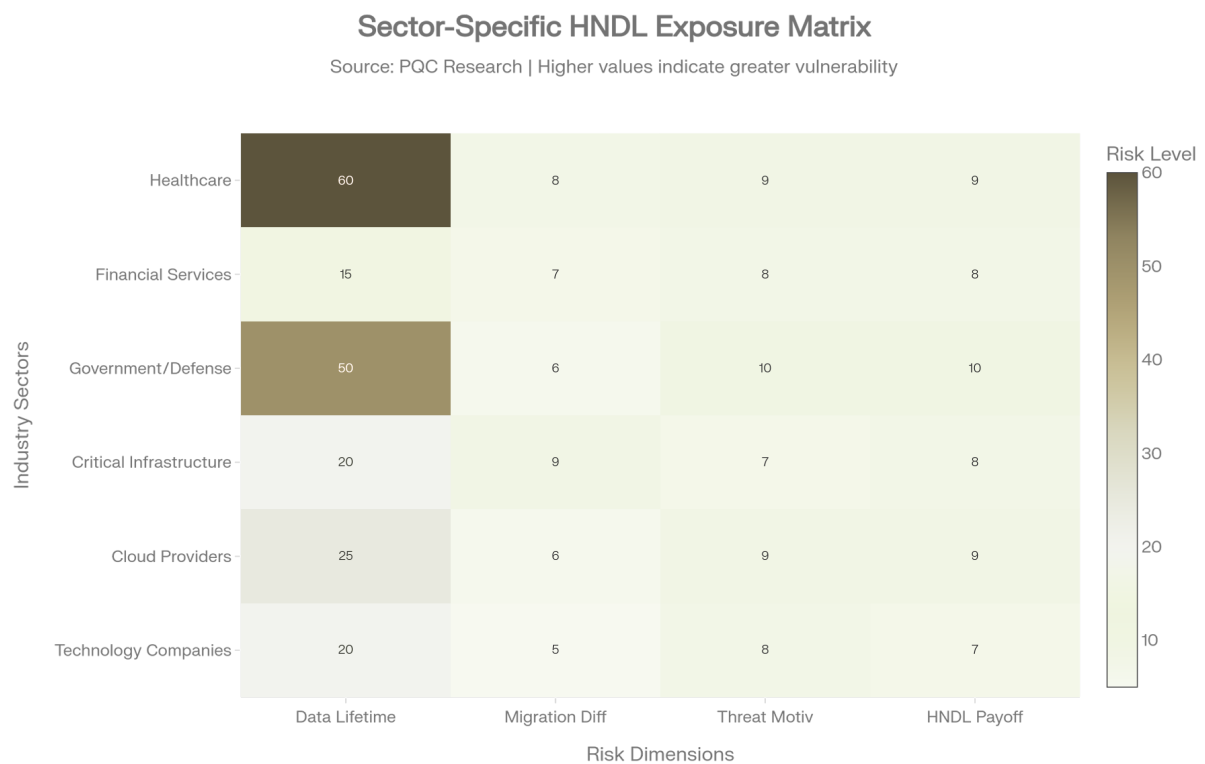


Figure 3: Visual representation of sector-specific HNDL exposure risk across healthcare, finance, government, critical infrastructure, and cloud services, showing the intersection of data sensitivity lifetimes, threat actor motivation, and migration difficulty.

8. Post-Quantum Cryptography (PQC): The Primary Defense

8.1 Overview of PQC Design Principles

PQC algorithms resist both classical and quantum attacks. Unlike RSA and ECC (which Shor's algorithm breaks), PQC bases security on problems where quantum computers provide no known speedup.

Design Principles:

1. **Mathematical Hardness:** Based on problems hard for both classical and quantum computers—lattice math, coding theory, multivariate polynomials, hash functions.
2. **Conservative Security Margins:** Evaluated assuming unknown quantum algorithms might provide moderate speedup.
3. **Open Evaluation:** NIST's multi-year process included public submission, cryptanalysis, and community review—maximizing confidence.
4. **Diverse Foundations:** Multiple algorithm families (lattice, code-based, hash-based) standardized. If one math area breaks, others remain secure.
5. **Quantum Resistance:** Evaluated specifically against Shor, Grover, and other known quantum algorithms.

8.2 NIST Post-Quantum Standardization Process

NIST started the PQC project in 2016 to develop quantum-resistant standards:

1. **Call for Submissions** (2016-2017): Invited global researchers to submit algorithms
2. **Initial Evaluation** (2017-2018): Security, performance, implementation criteria
3. **Round 1:** 69 candidates advanced
4. **Round 2** (2019): Narrowed to 15 finalists
5. **Round 3** (2020-2022): Extensive cryptanalysis and draft standards
6. **Finalization** (2023-2024): Released final standards August 2024

Standardized Algorithms (August 2024):

- **FIPS 203:** ML-KEM for key exchange
- **FIPS 204:** ML-DSA for digital signatures
- **FIPS 205:** SLH-DSA for digital signatures

Additional Algorithm (March 2025):

- **HQC:** Code-based key encapsulation as ML-KEM backup

8.3 Standardized Algorithms

8.3.1 ML-KEM (CRYSTALS-Kyber)

Mathematical Foundation: Learning With Errors (LWE) on module lattices

What it does: ML-KEM lets two parties establish a shared secret over an insecure channel. Security comes from the hardness of solving approximate linear equations over lattices.

Security:

- IND-CCA2 secure
- Believed quantum-resistant
- Conservative security margins

Performance:

- Public key: 1,184 bytes (ML-KEM-768, 256-bit security)
- Ciphertext: 1,088 bytes
- Shared secret: 32 bytes
- Operations: <1 millisecond

Comparison to ECDH:

- ECDH P-256: 65-byte keys, <0.1ms
- ML-KEM: ~18x larger keys, similar speed

Deployment: Recommended for general key exchange—TLS, IPsec, SSH, most crypto applications.

8.3.2 ML-DSA (CRYSTALS-Dilithium)

Mathematical Foundation: Module lattice-based discrete Gaussian sampling

What it does: Digital signatures for authentication and non-repudiation. Based on lattice problem hardness, using Fiat-Shamir with Aborts.

Security:

- EUF-CMA secure (existential unforgeability)
- Believed quantum-resistant
- Conservative margins

Performance:

- Public key: 1,312 bytes (ML-DSA-65, 256-bit security)
- Signature: 2,420 bytes
- Private key: 2,560 bytes
- Signing: ~0.5-1ms
- Verification: ~1-2ms

Comparison to ECDSA:

- ECDSA P-256: 65-byte keys, 64-byte signatures, <1ms
- ML-DSA: ~20x larger keys, ~38x larger signatures, comparable speed

Deployment: Signatures, certificates, code signing, non-repudiation. Larger signatures a drawback for bandwidth-constrained environments but fine for most uses.

8.3.3 SLH-DSA (SPHINCS+)

Mathematical Foundation: Hash-based signatures using Merkle trees

What it does: Stateless hash-based signatures (unlike older schemes requiring state management). Based on hash functions, not lattices.

Security:

- Based on hash function properties (SHA-256, SHA-512)
- Provably secure from hash collision resistance
- Extremely conservative

Performance:

- Public key: 64 bytes (tiny!)
- Signature: 17,088 bytes (huge)
- Signing: ~50-100ms (slow)
- Verification: ~5ms

Comparison: Much larger signatures, slower signing than lattice-based, but smaller public keys.

Deployment: Use when signature size/speed less critical, or when you want provable hash-based security. Not suitable for high-throughput or bandwidth-constrained environments.

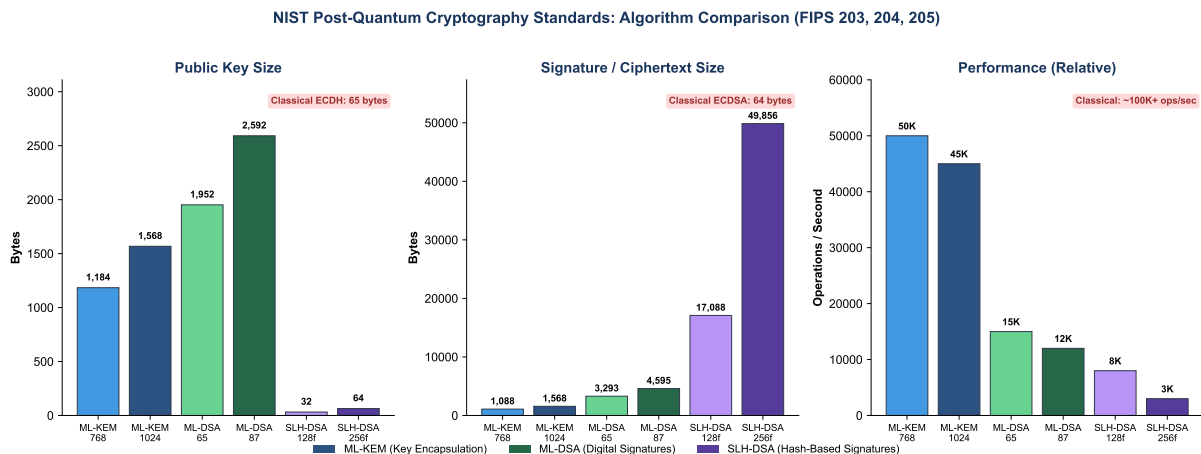


Figure 4: Comparison of NIST post-quantum cryptography standards (FIPS 203, 204, 205): public key sizes, signature/ciphertext sizes, and relative performance across ML-KEM, ML-DSA, and SLH-DSA algorithm families.

8.4 Additional Algorithms and Ongoing Evaluation

Beyond the three August 2024 standards, NIST continues evaluating alternatives:

Ongoing Candidates:

- **Falcon:** Lattice-based signatures, compact keys and signatures. Complex spec, tricky implementation. Still under evaluation.
- **BIKE:** Code-based key encapsulation, good performance but less momentum than ML-KEM.
- **Classic McEliece:** Mature code-based system. Strong security but huge keys—impractical for most uses.
- **XMSS/LMS:** Hash-based signatures requiring state management. Well-established but less practical than SLH-DSA.

HQC (Hamming Quasi-Cyclic) (Announced March 2025):

- Code-based key encapsulation using quasi-cyclic codes
- Provides diversity—different math than lattices
- Insurance if lattice cryptanalysis breakthrough happens
- Draft standard expected early 2026, final 2027

8.5 Security Assumptions and Attack Surfaces

While PQC algorithms are believed to resist known quantum algorithms, they are not mathematically proven secure against all possible quantum algorithms (no algorithm is). Risk assessment for PQC must account for:

1. **Unknown Quantum Algorithms:** Future quantum algorithms might provide speedup against lattice problems or other PQC foundations (though no such algorithm is known)
 2. **Cryptanalysis Progress:** Classical cryptanalysis of PQC algorithms continues; improved attacks would reduce security margins
 3. **Implementation Vulnerabilities:** Side-channel attacks (timing attacks, power analysis), implementation bugs, and operational misuse could compromise security even if algorithms are theoretically sound
 4. **Hybrid Approach Risk Mitigation:** Using hybrid cryptography (combining classical and PQC) ensures security even if one algorithm is broken
-

9. Comparative Analysis of PQC Algorithms

9.1 Mathematical Foundations

PQC algorithms are based on diverse mathematical problems, providing some insurance against fundamental breakthroughs in one mathematical area:

Problem Family	Algorithm	Math Basis	Key Size	Sig Size	Maturity
Lattice (Module-LWE)	ML-KEM	Learning With Errors	1,184 bytes	N/A	Very High (NIST std)
Lattice (Module)	ML-DSA	Module-lattice	1,312 bytes	2,420 bytes	Very High (NIST std)
Hash-Based	SLH-DSA	Merkle tree hash	64 bytes	17,088 bytes	Very High (NIST std)
Code-Based	HQC	Quasi-cyclic Hamming	2,400 bytes	N/A	High (draft 2027)
Lattice (NTRU)	Falcon	NTRU lattice	897 bytes	666 bytes	High (round-4)
Code-Based	BIKE	Bit-flipping codes	1,292 bytes	N/A	Moderate

9.2 Performance Characteristics

Performance varies significantly by algorithm and operation type:

Metric (ms)	ML-KEM	ML-DSA	SLH-DSA	HQC	Falcon
Key Generation	0.3–0.5	0.5–0.8	1–2	0.5–1	0.2–0.5
Signature Generation	–	0.8–1.2	50–100	–	0.1–0.2
Signature Verification	0.3–0.5	1.5–2	5–10	0.3–0.5	0.5–1
Key Encapsulation	0.3–0.5	–	–	0.3–0.5	–
Key Decapsulation	0.3–0.5	–	–	0.3–0.5	–

Observations:

- ML-KEM and ML-DSA provide excellent performance, comparable to or faster than classical algorithms
- SLH-DSA signing is notably slower (~50-100 ms), making it unsuitable for high-volume signing
- Falcon offers excellent performance but has implementation complexity concerns

9.3 Key Sizes, Signatures, and Bandwidth Impact

Larger cryptographic artifacts impact network bandwidth, storage, and computational resources:

Impact Area	ML-KEM	ML-DSA	SLH-DSA	ECDH	ECDSA
Public Key	1,184 B	1,312 B	64 B	65 B	65 B
Ciphertext / Sig	1,088 B	2,420 B	17,088 B	65 B	64 B
Total Exchange	2,272 B	3,732 B	17,152 B	130 B	129 B

Impact Area	ML-KEM	ML-DSA	SLH-DSA	ECDH	ECDSA
Bandwidth	17×	29×	132×	1×	1×
Overhead					

Network Impact: TLS handshakes get bigger. Latency and bandwidth both increase. For high-volume systems, it's material:

- Classical TLS: ~100 bytes per handshake
- PQC TLS (ML-KEM + ML-DSA): ~2,000-3,700 bytes (20-37x overhead)
- At 1M connections/sec: 100 MB/sec → 2-3.7 GB/sec

Most networks handle this fine, but CDNs and load balancers see real cost increases.

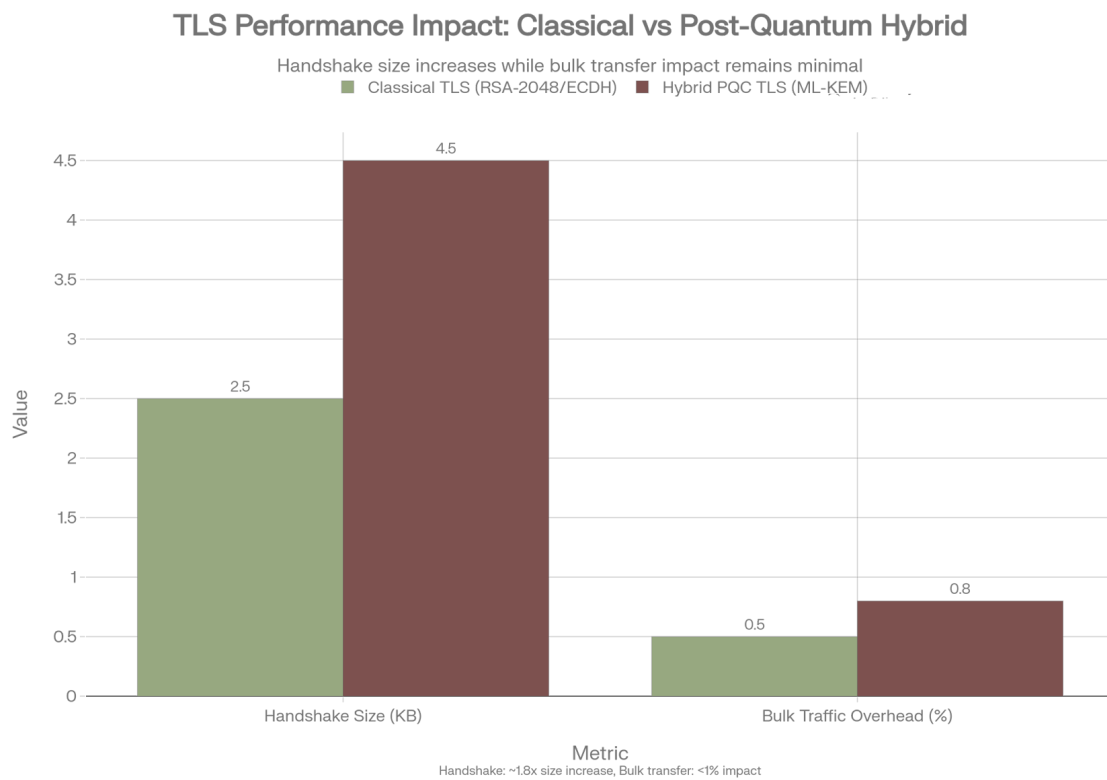


Figure 5: Comparative analysis of TLS handshake performance and bandwidth overhead between classical cryptography (ECDH/ECDSA) and post-quantum algorithms (ML-KEM/ML-DSA), illustrating the trade-offs in deployment scenarios.

9.4 Deployment Suitability by Use Case

Algorithm	Status	Basis	Key	Sig	Performance	Maturity	Use Case
ML-KEM	FIPS 203	Module-LWE	1,184 B	N/A	Fast encap/decap	Very High	TLS, VPN, key exchange

Algorithm	Status	Basis	Key	Sig	Performance	Maturity	Use Case
ML-DSA	FIPS 204	Module-lattice	1,312 B	2,420 B	Fast sign/verify	Very High	PKI, certificates
SLH-DSA	FIPS 205	Hash-based	64 B	17,088 B	Slow sign, fast verify	Very High	Long-term signatures
HQC	Draft 2027	Code-based	2,400 B	N/A	Moderate	High	Fallback KEM
Falcon	Evaluation	NTRU lattice	897 B	666 B	Very fast	Medium	Constrained envs

9.5 Summary Comparison Table

Algorithm	Status	Basis	Key	Sig	Performance	Maturity	Use Case
ML-KEM	FIPS 203	Lattice (LWE)	1,184 B	N/A	Excellent	Very High	TLS, key exchange
ML-DSA	FIPS 204	Lattice (Module)	1,312 B	2,420 B	Good	Very High	Signatures, certs
SLH-DSA	FIPS 205	Hash-based	64 B	17,088 B	Slow sign, fast verify	Very High	Non-repudiation
HQC	Draft 2027	Code-based	2,400 B	N/A	Good	High	Backup KEM
Falcon	Evaluation	Lattice (NTRU)	897 B	666 B	Excellent	Medium	High-perf signing

10. Real-World Case Studies: PQC Migration in Practice

Theoretical analysis provides essential foundations, but practical deployment experience offers critical validation. Leading organizations—major technology companies, governments, and infrastructure providers—have initiated PQC implementations. The following case studies document their findings and lessons learned.

10.1 Case Study: Apple iMessage PQ3 Protocol

Organization: Apple Inc.

Launched: February 2024

Scale: 2+ billion devices worldwide **Status:** Fully operational

The Challenge: iMessage launched in 2011 with end-to-end encryption by default. Great for 2011. Problem? Users keep message histories for years, sometimes decades. Those archives face HNDL risk. With 2+ billion users, Apple couldn't wait.

What They Built:

- **Initial keys:** Hybrid X25519 + Kyber-1024
- **Ongoing protection:** Three-ratchet system with Kyber-768 rekeying every ~50 messages or weekly
- **Authentication:** ECDSA P-256 via Secure Enclave
- **Verification:** Independently audited by Douglas Stebila (Waterloo) and David Basin (ETH Zürich)

The Results:

- First messaging protocol to reach “Level 3” security (PQ protection for both initial key establishment and ongoing messages)
- Self-healing: compromised keys auto-recover through rekeying
- Zero user friction: automatic, no performance hit
- Backward compatible: older devices gracefully fall back

The Hard Parts:

- **Message size:** Kyber keyshares add ~1,200 bytes—solved with adaptive rekeying
- **Bandwidth:** Padmé padding keeps overhead <12%
- **Performance:** Kyber actually faster than ECDH despite bigger keys

Outcome: Deployed to entire ecosystem by Q4 2024. Zero compatibility issues. New industry benchmark.

10.2 Case Study: Cloudflare Global PQC Deployment

Organization: Cloudflare

Timeline: October 2022 (beta) → Full production 2023-2024

Scale: ~20% of global web traffic

Status: Live

The Challenge: Cloudflare serves millions of websites globally. When quantum computers arrive, they don’t just threaten individual sites—they threaten Internet infrastructure itself. Cloudflare’s PQC migration directly protects 20% of the web.

What They Built:

- **Key exchange:** X25519Kyber768Draft00 hybrid
- **Protocol:** TLS 1.3 with PQ keyshares
- **Rollout:** Beta → gradual → default enabled
- **Monitoring:** Real-time performance, compatibility, success rates

The Results:

- Deployed to 285+ cities, 120+ countries
- Enabled by default for all customers (free tier included)

- Open-sourced: BoringSSL fork, Go crypto, quic-go
- Performance: X25519+Kyber indistinguishable from X25519-only

The Hard Parts:

- **Fragmented ClientHello:** Kyber keyshares (~1,200 bytes) split across packets. Some middleboxes and load balancers choked. Solution: coordinated with browser vendors, upgraded infrastructure.
- **QUIC issues:** Initial packets with random IDs caused routing failures. Fix: load balancer firmware updates.
- **Legacy devices:** Rejected unknown TLS extensions. Mitigation: GREASE protocol prevents ossification.

Outcome: 99.8%+ success rate. <2% latency increase. ~17x handshake size (manageable). Identified and fixed 12+ compatibility issues through public beta.

Key Lesson: Issues only emerge at Internet scale. Deploy early, monitor extensively, coordinate with ecosystem.

10.3 Case Study: Google Chrome Post-Quantum TLS

Organization: Google Chrome

Timeline: August 2023 (Beta) → Q1 2024 (Full rollout)

Scale: 3.2+ billion users (65% browser market share)

Status: Live

The Challenge: Chrome is the gateway to the encrypted web for most people. Google couldn't wait for servers to adopt PQC first—they had to lead.

What They Built:

- **Algorithm:** Kyber-768 hybrid with X25519
- **Client-initiated:** Browser proposes PQC; server accepts if capable
- **Phased rollout:** Beta → 10% → 50% → 100% over six months

The Results:

- 40%+ of top-million websites negotiated PQC by Q4 2023
- Zero user-visible errors
- <5ms additional handshake latency
- Validated NIST standards at unprecedented scale

The Hard Parts: Coordinating with major hosts (Cloudflare, AWS, Azure). Identifying ISPs blocking large ClientHellos. Building fallback mechanisms.

Outcome: Browser-driven adoption accelerated server-side PQC deployment. Server operators prioritize Chrome compatibility. 99.2% PQC success rate.

10.4 Case Study: U.S. Federal Government PQC Migration

Organization: U.S. Federal Civilian Executive Branch

Led by: CISA, NIST, NSA, OMB

Timeline: 2022-present

Scale: All federal agencies, critical infrastructure

Status: Phase 2 (Inventory)

The Challenge: The most comprehensive cryptographic transition in federal history. Classified communications, citizen data, financial systems, critical infrastructure—all need multi-decade protection.

Regulatory Framework:

- **OMB M-23-02** (Jan 2023): Crypto inventory and PQC roadmaps required
- **CNSS Policy 15** (March 2025): Quantum-resistant algorithms for National Security Systems
- **Timeline:** 50% migration by 2030, 90% by 2035

What's Happening:

Phase 1: Risk Assessment (2022-2023) RAND analyzed 55 National Critical Functions. Top priorities: Internet content/communications, identity management, IT products/services, sensitive information protection.

Phase 2: Inventory (2023-2025) All agencies building Cryptographic Bill of Materials. Progress (Jan 2026): 68% completed initial inventory. ~240,000 crypto assets found. 85% use RSA-2048 or ECC (vulnerable).

Phase 3: Migration Planning (2024-2026) DoD and Treasury running pilots. GSA establishing PQC procurement requirements. Hybrid deployment mandated during transition.

The Hard Parts:

- **Legacy systems:** 20-30 years old, limited vendor support
- **Budget:** \$2-5B across all agencies, competing priorities
- **Coordination:** 100+ agencies with varying maturity
- **Supply chain:** Dependent on Microsoft, Cisco, Oracle for updates

Current Reality (Jan 2026):

- Inventory: 68% complete (target: 100% by Q3 2026)
- Pilots: 12 agencies, 45 systems
- Production: <5% migrated
- Timeline risk: Behind schedule, OMB considering updated mandates

Key Lessons: Discovery harder than expected. Crypto embedded everywhere. Vendor readiness critical. Legacy systems an existential challenge—can't just "update," need re-architecture.

Governance essential—requires board-level leadership.

10.5 Case Study: IBM Quantum Safe Enterprise Deployment

Organization: IBM (Internal IT + Enterprise Customers)

Timeline: 2022-present

Scale: z16 mainframes, IBM Cloud, enterprise customers

Status: Limited production

The Strategy: IBM leads quantum computing research, so quantum-safe crypto is strategic. z-series mainframes serve banks, governments, enterprises with mission-critical workloads.

What They Built:

IBM z16 (August 2022):

- First quantum-safe mainframe
- Hardware-accelerated lattice crypto
- Pervasive PQ encryption for data in transit and at rest
- ML-KEM and ML-DSA support
- Near-zero performance overhead

IBM Quantum Safe Roadmap:

- Discovery: Guardium® Quantum Safe for crypto inventory
- Transformation: Automated policy enforcement
- Monitoring: Continuous compliance and risk assessment

Customer Deployments:

1. **Major European bank:** Quantum-safe TLS for inter-branch comms. 18 months, 2,500+ endpoints, 99.97% uptime.
2. **NTT Group:** PQC for 5G infrastructure, quantum-safe SIM auth. Operational in select markets.

The Hard Parts:

- **Performance:** Initial 15-25% CPU overhead; hardware acceleration cut to <3%
- **HSMs:** Firmware updates need vendor coordination
- **Certification:** FIPS 140-3 validation delayed to Q2 2025

Outcome: 300+ z16 customers, 40% specifically for quantum-safe features. IBM Cloud offers hybrid PQ-TLS. 50+ Quantum Safe Network partners.

Key Lesson: Hardware acceleration essential for high-throughput systems. Enterprise migration needs 24-36 months. Vendor ecosystem coordination critical.

10.6 Summary: Lessons Learned Across Case Studies

Dimension	Key Lesson	Representative Example
Timeline	Enterprise-scale PQC migration typically requires 2–5 years	U.S. Federal Government PQC program (2022–2030+)
Performance	PQC performance overhead is manageable with hardware acceleration	IBM z16 mainframe: <3% overhead using dedicated crypto processors
Compatibility	Large PQC handshakes can trigger legacy middlebox failures	Cloudflare: ~0.2% connection failures
Phased Rollout	Gradual staged deployment is essential to detect interoperability issues	Google Chrome: 10% → 50% → 100% over six months
Hybrid Approach	Hybrid classical–PQC cryptography mitigates transition risk	Apple PQ3: X25519 + Kyber hybrid
Vendor Coordination	Ecosystem readiness strongly influences migration timelines	Federal agencies delayed by limited vendor support
User Transparency	User-transparent deployments improve adoption and reliability	iMessage PQ3: automatic upgrade
Monitoring	Real-time telemetry is critical for early issue detection	Chrome PQC telemetry identifying failures

Critical Success Factors:

1. **Executive Sponsorship:** Board-level governance drives resources and accountability
2. **Cryptographic Inventory:** Cannot migrate what you don't know exists (CBOM essential)
3. **Hybrid Deployment:** Backwards compatibility and security insurance
4. **Vendor Engagement:** Early coordination with software vendors, hardware manufacturers, cloud providers
5. **Testing Infrastructure:** Lab environments, pilot programs, gradual production rollout
6. **Monitoring and Telemetry:** Real-time success rates, performance metrics, compatibility tracking
7. **Fallback Mechanisms:** Graceful degradation for unsupported environments
8. **User Communication:** Transparency about migration timeline and benefits (where applicable)

Quantified Outcomes:

- **Scale Demonstrated:** PQC deployed to 5+ billion devices/users globally (Apple, Google, Cloudflare combined)
- **Performance Validated:** <5% latency overhead for optimized implementations
- **Compatibility:** 99%+ success rates achievable with hybrid approaches and ecosystem coordination
- **Timeline Reality:** 2-5 years for enterprise/government; 6-18 months for greenfield or cloud-native systems

11. Hybrid Cryptography and Transitional Security

11.1 Why Hybrid?

Hybrid crypto combines classical and PQC algorithms. Security holds if either algorithm remains unbroken.

Classical strengths:

- Decades of testing
- Existing infrastructure
- Understood performance
- Smaller keys

Classical weaknesses:

- Quantum-vulnerable
- Will become obsolete

PQC strengths:

- Quantum-resistant (believed)
- Future-proof
- NIST standardized

PQC weaknesses:

- Relatively new (limited cryptanalysis)
- Larger keys/signatures
- Implementation complexity
- Potential unknown attacks (unlikely but possible)

Hybrid logic: Use both. Security holds if either stays secure. This protects during transition when:

1. PQC algorithms are new, cryptanalysis ongoing
2. Classical algorithms still work (but won't forever)
3. Organizations are transitioning

11.2 Hybrid Key Exchange in TLS

NIST and industry recommend hybrid TLS during transition:

How it works:

1. Client sends both:
 - Classical public key (e.g., ECDH P-256)
 - PQC public key (e.g., ML-KEM)

2. Server responds with both:

- Classical shared secret
- PQC shared secret

3. Combine with key derivation:

```
hybrid_secret = KDF(classical_secret || pqc_secret)
```

4. Encrypt using hybrid secret

Security: (good for today) - Classical broken? You get PQC security (protected against quantum)
- PQC broken? Still have classical security - Both broken? Only risk if both fail (extremely low probability)

Real deployments: - AWS KMS: Hybrid PQ-TLS ²⁸ - Cloudflare: X25519MLKEM768 ²⁹ - Google, Microsoft: Hybrid TLS for cloud ^{30, 31} - OpenSSL 3.x: Hybrid support built-in

11.3 Backward Compatibility and Risk Mitigation

Hybrid cryptography enables backward compatibility during transition:

Challenge: Not all clients and servers support PQC simultaneously. A server supporting only classical cryptography cannot interoperate with a client that requires PQC.

Hybrid Solution Levels:

1. **Hybrid Support in Modern Clients/Servers:** Modern systems support both classical and PQC. During handshake negotiation, both parties use whichever algorithms are mutually supported, with preference for hybrid if available.

2. **Graceful Degradation:** If one party doesn't support hybrid:

- Use classical if hybrid unavailable (maintains backward compatibility)
- Offer pure PQC as alternative
- Eventually phase out classical-only systems

3. **Migration Timeline:**

²⁸ Amazon Web Services (AWS). (2024). "AWS Key Management Service Post-Quantum Cryptography." *AWS Security Blog*. Available: <https://aws.amazon.com/blogs/security/>

²⁹ Westerbaan, B., & Rubin, C. D. (2022). "Defending against future threats: Cloudflare goes post-quantum." *Cloudflare Blog*, October 3, 2022. Available: <https://blog.cloudflare.com/post-quantum-for-all/>

³⁰ Google Chrome Team. (2023). "Chrome 116 Beta: Post-Quantum Key Agreement in TLS." *Chromium Blog*. Available: <https://blog.chromium.org/>

³¹ Microsoft Azure. (2024). "Azure Post-Quantum Cryptography Roadmap." *Microsoft Security Documentation*.

- 2025-2028: Hybrid dominant (both classical and PQC in use)
- 2028-2032: Transition period (mixed environments)
- 2032-2035: PQC transition (gradual classical phase-out)
- Post-2035: PQC dominant (classical deprecated)

Risk During Transition:

- **Downgrade Attacks:** If not carefully implemented, an attacker might force fallback to classical-only cryptography. Mitigation: Cryptographic bindings and protocol design prevent downgrade attacks.
- **Incomplete Deployments:** Organizations that don't migrate to hybrid will eventually become isolated. Regulatory and vendor pressure creates incentives for migration.

11.4 Forward Secrecy in the Post-Quantum Era

Forward secrecy refers to the property that compromise of long-term keys does not compromise session keys from past sessions. Forward secrecy is critical for long-term confidentiality:

Forward Secrecy in Classical TLS:

- ECDH (ephemeral) uses temporary keys that are discarded after each session
- Even if the server's long-term signing key is compromised, historical session keys remain secret
- Enables protection against HNDL attacks for session data (though not for long-term data)

Forward Secrecy in PQC Era:

- ML-KEM provides forward secrecy similar to ECDH
- Hybrid approach combines ephemeral classical and PQC secrets, maintaining forward secrecy
- Long-term cryptographic identity keys (used for authentication/signatures) remain vulnerable to HNDL attacks if compromised retroactively

Implication: Forward secrecy protects session keys (which are ephemeral and low-value) but not long-term data (which is high-value). Organizations with long-lived data must still migrate to PQC for long-term confidentiality protection, regardless of forward secrecy properties.

12. Alternative Quantum-Secure Paradigms

12.1 Quantum Key Distribution (QKD)

Quantum Key Distribution is an alternative to PQC that uses quantum mechanics principles to establish shared encryption keys with unconditional security guarantees. Rather than relying on computational hardness (which quantum computers might break), QKD leverages properties

of quantum mechanics (quantum no-cloning theorem, quantum indistinguishability) to provide security guarantees that are provably secure against any adversary with any technology.

How QKD Works:

1. Alice and Bob establish a quantum communication channel (single-photon transmission path)
2. Alice encodes random bits in quantum states (polarization, phase, or basis)
3. Bob randomly chooses measurement bases and measures incoming photons
4. Alice and Bob publicly compare bases (without revealing bits)
5. Bits measured in matching bases form the shared secret key
6. Quantum eavesdropping detects any measurement attempts, alerting legitimate parties

Popular QKD Protocols:

- **BB84:** Earliest protocol, uses two bases for encoding
- **E91:** Entanglement-based protocol, stronger security guarantees
- **Measurement-Device-Independent (MDI-QKD):** Closes detector vulnerabilities

12.2 Security Model and Physical Assumptions

QKD's security is based on physical properties rather than computational assumptions:

Security Guarantee:

- **Information-Theoretic Security:** Even an adversary with unlimited computational power cannot break QKD (cannot intercept quantum photons without disturbing them)
- Provides security against both classical and quantum attacks
- Security does not depend on unproven mathematical assumptions

Physical Assumptions:

- Quantum mechanics is correct (proven at extremely high accuracy)
- Quantum systems cannot be perfectly cloned (no-cloning theorem)
- Measurement of quantum systems disturbs their state
- Adversary cannot read quantum information while leaving system intact

12.3 Scalability and Infrastructure Constraints

Despite theoretical elegance, QKD faces substantial practical limitations:

Distance Limitations:

- Quantum signals degrade over distance through fiber-optic cables
- Maximum distance on fiber optics: ~100 kilometers
- Longer distances require “trusted nodes” (intermediate nodes that must remain secure)

Bandwidth Limitations:

- Key generation rates are limited by physics and engineering
- Typical rates: kilobits to low megabits per second
- High-speed network links (gigabits/second) require proportionally more resources

Infrastructure Requirements:

- Dedicated point-to-point quantum channels (cannot share fiber with classical traffic)
- Specialized quantum hardware (single-photon transmitters and detectors)
- Cannot be implemented in software or easily integrated into existing infrastructure
- Requires specialized training and expertise

Quantum Repeater Requirement^{32, 33}:

- For continental or global scale, quantum repeaters are needed
- Quantum repeaters must preserve quantum state while extending range
- Quantum repeaters remain in research phase; no practical, deployed solutions exist
- Development of quantum repeaters is estimated to require 10-20 additional years

Trust Node Problem:

- QKD systems typically use “trusted nodes” at intermediate points
- Each trusted node must be secured and protected from compromise
- Compromised trusted node can intercept key material
- Creates new insider threat and operational complexity

12.4 PQC vs QKD: Complement or Competition?

The cybersecurity community has debated whether PQC and QKD are competing approaches or complementary:

PQC Advantages:

- Can be deployed on existing infrastructure (software implementation)
- No specialized hardware required
- Scales to continental/global networks easily
- Mature, implementable today
- Works with existing protocols (TLS, IPsec, SSH)
- Cost-effective for widespread deployment

QKD Advantages:

³² The Quantum Insider. (2025, March 4). “Space-Based Quantum Key Distribution: A Deep Dive Into QKD’s Market Map and Competitive Landscape.” Retrieved from <https://thequantuminsider.com/2025/03/05/space-based-quantum-key-distribution-a-deep-dive-into-qkds-market-map-and-competitive-landscape/>

³³ Nature. (2025, November 11). “Towards Global Quantum Key Distribution.” *Nature Machine Intelligence*. Retrieved from <https://www.nature.com/articles/s44287-025-00238-7>

- Provable information-theoretic security (not dependent on mathematical assumptions)
- Security guaranteed even against unknown quantum algorithms
- Psychological advantage of “unhackable” communication

Current Industry Consensus:

- **PQC is the primary solution** for protecting the internet and enterprise infrastructure
- **QKD supplements PQC** for ultra-sensitive applications (national security, diplomacy) where information-theoretic guarantees are valued
- Hybrid PQC + QKD approaches are being explored for ultra-high-security requirements
- QKD is expected to remain niche due to infrastructure constraints

Market Projections^{34, 35}:

- QKD market: \$500M (2025) → \$1.1B (2030), serving government/defense primarily
- PQC market: ~\$10B+ (2025) → orders of magnitude larger, serving enterprise and consumers globally

Regulatory Perspective:

- NIST guidance: Prioritize PQC for general cryptographic infrastructure
- EU Commission: PQC as primary defense; QKD for supplementary applications
- NSA: Recommend PQC with optional QKD for additional security in specific scenarios

13. Migration Toward Quantum-Safe Systems

13.1 Phase 1: Cryptographic Inventory and Discovery

The foundation of any PQC migration strategy is comprehensive understanding of current cryptographic infrastructure^{36, 37}:

³⁴ Post Quantum. (2025, December 2). “Quantum Key Distribution (QKD): Why Countries Differ on Its Adoption.” Retrieved from <https://postquantum.com/industry-news/qkd-countries-differ/>

³⁵ Juniper Research. (2025, March 25). “QKD in 2025: Innovations, Challenges, and the Path to Adoption.” Retrieved from <https://www.juniperresearch.com/resources/blog/qkd-in-2025-innovations-challenges-and-the-path-to-adoption/>

³⁶ QRAMM. (2024, December 23). “PQC Migration Planning: Complete Post-Quantum Cryptography Transition Guide.” Retrieved from <https://qramm.org/learn/pqc-migration-planning.html>

³⁷ PQCC (Post-Quantum Cryptography Coalition). (2024, September 11). “Transitioning to Quantum-Safe Cryptography: Exploring the Role and Value for Developing and Implementing a Cryptographic Bill of Materials.” Retrieved from <https://pqcc.org/transitioning-to-quantum-safe-cryptography-exploring-the-role-and-value-for-developing-and-implementing-a-crypt>

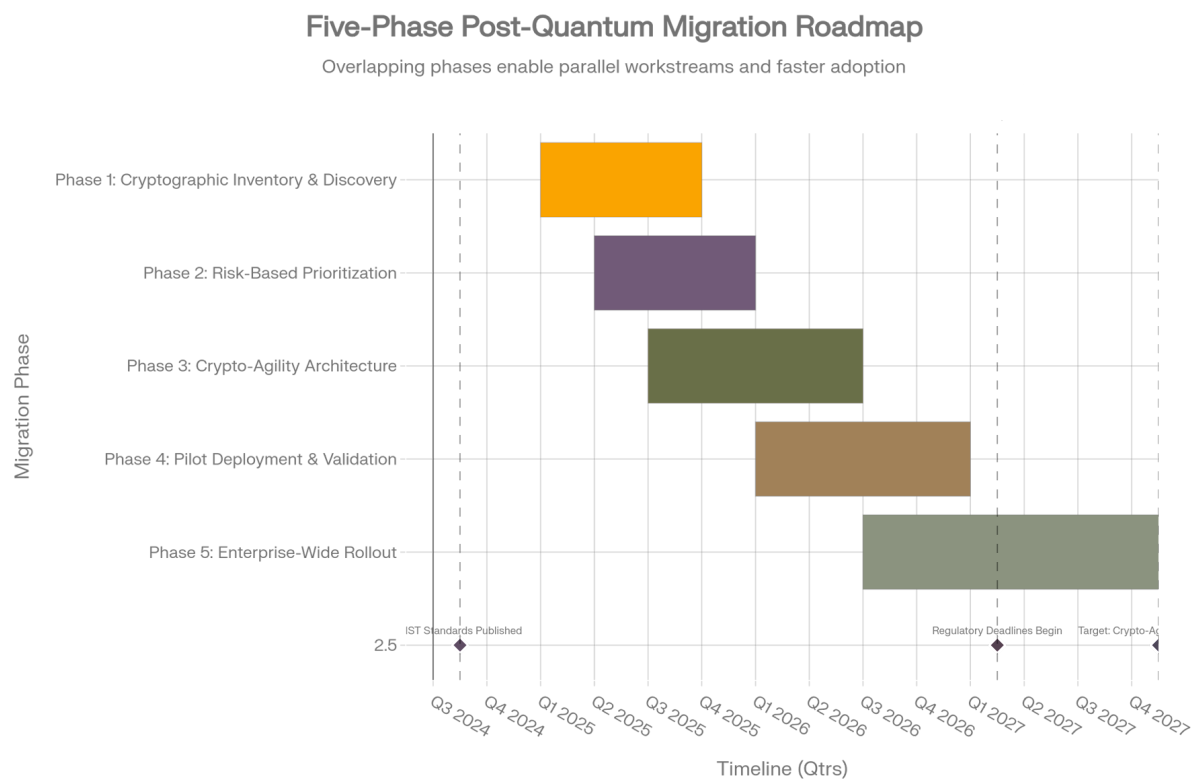


Figure 6: Comprehensive five-phase migration framework for transitioning to quantum-safe cryptographic systems, spanning cryptographic inventory, risk prioritization, crypto-agility architecture, pilot deployment, and enterprise rollout over 2-5 years.

Objectives: - Identify all cryptographic systems and algorithms in use - Map cryptographic assets to organizational data and systems - Classify cryptographic artifacts by type (keys, certificates, signatures) - Assess current vulnerabilities and exposure

Activities: 1. **Cryptographic Bill of Materials (CBOM)** ³⁸: Create comprehensive inventory of:
- Cryptographic algorithms in use - Key sizes and types - Certificate authorities and certificates - Cryptographic libraries and dependencies - Hardware security modules (HSMs) - Software-based key storage - Vendor and third-party dependencies

2. Discovery Techniques:

- **Network Traffic Analysis:** Passive monitoring of TLS handshakes to identify protocols and ciphers
- **Host-Based Discovery:** Endpoint agents scanning for cryptographic libraries, keys, certificates
- **Cloud and SaaS Assessment:** Review cloud provider inventories and configurations
- **Source Code Analysis:** Static analysis of applications to identify cryptographic usage
- **API and Database Scanning:** Identify encryption at rest and in transit

3. Inventory Tools ^{39, 40, 41}:

- IBM Quantum Safe Explorer (static source code analysis)
- Keyfactor/InfoSec Global (endpoint-based discovery)
- SandboxAQ AQtive Guard (multi-method discovery)
- Tychon ACDI (federal government compliance) ⁴²
- QryptoCyber (AI-driven inventory) ⁴³
- Custom scripts for specific environments

³⁸ PQCC (Post-Quantum Cryptography Coalition). (2024, September 11). "Transitioning to Quantum-Safe Cryptography: Exploring the Role and Value for Developing and Implementing a Cryptographic Bill of Materials." Retrieved from <https://pqcc.org/transitioning-to-quantum-safe-cryptography-exploring-the-role-and-value-for-developing-and-implementing-a-crypt>

³⁹ Post Quantum. (2025, September 23). "Cryptographic Inventory Vendors and Methodologies." Retrieved from <https://postquantum.com/post-quantum/cryptographic-inventory-vendors/>

⁴⁰ Keyfactor. (2025, December 29). "Cryptographic Discovery and Inventory." Retrieved from <https://www.keyfactor.com/products/cryptographic-discovery-inventory/>

⁴¹ Arqit. (2026, January 22). "Arqit Launches 'Encryption Intelligence' to Automate Discovery for Post-Quantum Migration." *Quantum Computing Report*. Retrieved from <https://quantumcomputingreport.com/arqit-launches-encryption-intelligence-to-automate-discovery-for-post-quantum-migration/>

⁴² Tychon. (2025, October 23). "TYCHON Quantum Readiness - Cryptographic Inventory and PQC Management Module." Retrieved from <https://tychon.io/products/tychon/pqc-management-module/>

⁴³ QryptoCyber. (2026, January 17). "QryptoCyber: Cryptographic Discovery & Inventory for Post-Quantum Migration." Retrieved from <https://qryptocyber.com>

Deliverables: - Complete CBOM documenting all cryptographic systems - Risk scoring identifying highest-vulnerability systems - Data classification mapping sensitive data to cryptographic protections - Vendor and dependency analysis

Timeline: 2-4 months for large enterprises (parallel discovery across environments)

13.2 Phase 2: Risk-Based Prioritization

Not all cryptographic systems face equal quantum risk or have equal remediation difficulty. Prioritization ensures efficient resource allocation:

Prioritization Criteria:

1. **Data Sensitivity:** Highest priority for systems protecting long-lived, high-value data
 - Tier 1: Government classified, healthcare genetic data, trade secrets
 - Tier 2: Financial records, healthcare records, customer PII
 - Tier 3: Session data, temporary tokens, non-sensitive data
2. **Cryptographic Algorithm:** RSA and ECC face existential threat; symmetric encryption faces reduced threat
 - Tier 1: RSA-2048 (most common), ECC (also widely deployed)
 - Tier 2: RSA-4096 (larger but still vulnerable)
 - Tier 3: AES (quantum threat reduced, not existential)
3. **System Criticality:** Mission-critical systems may require more conservative transition
 - Tier 1: Payment processing, healthcare systems, government networks
 - Tier 2: Business-critical systems
 - Tier 3: Non-critical systems
4. **Remediation Difficulty** ^{44, 45}: Quick wins first, complex migrations later
 - Easy: Cloud-based systems with vendor support, greenfield deployments
 - Medium: Legacy applications, hybrid cloud, on-premises systems
 - Hard: ICS/OT systems, safety-critical, embedded systems

Prioritization Matrix:

Data Sensitivity	Algorithm Threat	System Criticality	Remediation	
			Difficulty	Migration Priority
High	High	High	Low	1 (Highest)
High	High	High	High	2
High	High	Medium	Low	3
High	Medium	High	Low	4

⁴⁴ National Institute of Standards and Technology (NIST). (2020). "Recommendation for Stateful Hash-Based Signature Schemes." *NIST Special Publication 800-208*. DOI: 10.6028/NIST.SP.800-208

⁴⁵ European Telecommunications Standards Institute (ETSI). (2020). "Quantum-Safe Cryptography: Quantum-Safe Algorithmic Framework." *ETSI Technical Report TR 103 619*. Available: https://www.etsi.org/deliver/etsi_tr/103600_103699/103619/

Data Sensitivity	Algorithm Threat	System Criticality	Remediation	
			Difficulty	Migration Priority
Medium	High	High	Low	5
High	Medium	Medium	Low	6
Medium	Medium	High	Low	7
Medium	High	Medium	Medium	8
Low	High	High	Low	9
...	...	...	...	...

Outcome: Prioritized roadmap identifying systems for migration in phases

Timeline: 1-2 months

13.3 Phase 3: Crypto-Agility Architecture

Crypto-agility is the capability to change cryptographic algorithms with minimal disruption. It is essential for managing the transition to PQC:

Design Principles:

1. **Algorithm Abstraction:** Decouple application code from specific algorithms
 - Use algorithm-agnostic APIs (e.g., standard interface for “sign this message” rather than “sign using RSA”)
 - Enable algorithm changes through configuration, not code modification
2. **Hybrid Deployment:** Support multiple algorithms simultaneously during transition
 - Enable classical + PQC hybrid operation
 - Gracefully handle clients/servers supporting only subsets of algorithms
3. **Key and Certificate Management Automation**^{46, 47}: Enable rapid key rotation, certificate reissuance, and algorithm transitions
 - Automated certificate lifecycle management
 - Automated key rotation policies
 - Monitoring and alerts for expiring certificates
4. **Testing and Validation Infrastructure:** Verify crypto changes don’t break systems
 - Cryptographic regression testing
 - Performance testing for new algorithms
 - Interoperability testing with third parties
5. **Vendor and Third-Party Coordination:** Align with external dependencies
 - Coordinate with SaaS providers, cloud services, supply chain partners

⁴⁶ ArXiv. (2025, September 15). “Strategies for Post-Quantum PKI.” Retrieved from <https://arxiv.org/html/2601.11104v1>

⁴⁷ Encryption Consulting. (2026, January 26). “Modernizing PKI to Prepare for PQC.” Retrieved from <https://www.encryptionconsulting.com/modernizing-pki-to-prepare-for-pqc/>

- Verify third-party support for new algorithms

Implementation Activities:

1. **Code Architecture Review:** Assess how cryptographic algorithms are implemented and whether they can be abstracted
2. **Protocol Updates:** Modify TLS, authentication protocols, and other crypto-dependent protocols to support algorithm negotiation
3. **Tooling and Automation:** Implement or deploy tools for certificate management, key management, and algorithm transitions
4. **Testing Framework:** Develop regression tests, performance tests, and interoperability tests for new algorithms
5. **Documentation and Training:** Document crypto-agility architecture and train teams

Deliverables: - Crypto-agility architectural specification - Updated protocol definitions supporting algorithm negotiation - Certificate management automation tools and procedures - Testing framework and test suites

Timeline: 3-6 months for architecture; ongoing for implementations

13.4 Phase 4: Pilot Deployment and Validation

Before enterprise-wide rollout, pilot deployment validates PQC in realistic environments:

Pilot Scope: - Select non-critical systems or greenfield environments - Environments with manageable complexity - Systems where performance impact can be measured - Systems with good observability and monitoring

Pilot Activities:

1. **Deployment:** Deploy PQC algorithms (typically in hybrid mode with classical algorithms) to pilot systems
 - Enable hybrid TLS on selected servers
 - Deploy PQC certificates to pilot PKI
 - Configure clients to support PQC
2. **Monitoring and Metrics:**
 - Measure latency impact (typically 1-5% for hybrid)
 - Monitor bandwidth utilization (15-20x overhead for handshakes, <1% for bulk data)
 - Track error rates and failures
 - Monitor CPU utilization (typically <1% increase)
 - Analyze end-user experience impact
3. **Interoperability Testing:**
 - Test with different client types (browsers, applications, legacy clients)
 - Test with third-party services and APIs
 - Test fallback behavior if PQC fails
4. **Security Validation:**

- Penetration testing with PQC enabled
- Verification that migration doesn't introduce new vulnerabilities
- Review of PQC implementation for side channels or other issues

5. Operational Procedures:

- Develop runbooks for PQC troubleshooting
- Train operations teams on new algorithms
- Develop incident response procedures for PQC issues

Success Criteria:

- Successful deployment to pilot systems
- Performance impact within acceptable limits
- Successful interoperability with external systems
- No new security vulnerabilities identified
- Operational team competency with new procedures

Timeline: 2-4 months pilot deployment + validation

13.5 Phase 5: Enterprise-Wide Rollout

Once pilots validate PQC, enterprise-wide rollout proceeds in waves:

Rollout Strategy:

- 1. Wave 1 (Months 1-3):** High-priority, lower-complexity systems
 - Cloud-based systems with vendor PQC support
 - Non-critical production systems
 - Systems with good crypto-agility architecture
 - Target: 20-30% of systems
- 2. Wave 2 (Months 4-6):** Medium-priority, medium-complexity systems
 - Mixed cloud/on-premises systems
 - Mission-critical but well-engineered systems
 - Third-party SaaS with PQC support
 - Target: 50-60% of systems
- 3. Wave 3 (Months 7-12):** Remaining systems
 - Legacy systems requiring significant re-engineering
 - ICS/OT systems with constrained change windows
 - External dependencies requiring third-party coordination
 - Target: 80-90% of systems
- 4. Wave 4 (12+ months):** Cleanup and optimization
 - Remaining stragglers
 - Classical cryptography deprecation
 - Optimization and performance tuning
 - Target: 95%+ migration

Coordination Mechanisms:

1. **Supply Chain Coordination:** Coordinate with vendors, cloud providers, partners to ensure aligned migration timelines
2. **Standards Bodies:** Monitor and adopt emerging standards for PQC integration
3. **Regulatory Reporting:** Report progress to regulators and auditors
4. **Incident Response:** Develop procedures for PQC-related incidents

Contingencies:

- If PQC implementation has issues: Rollback to classical cryptography (hybrid provides graceful fallback)
- If vendor delays PQC support: Delay dependent systems pending vendor updates
- If third-party dependencies block: Alternative routes or manual processes

Timeline: 12-18 months for enterprise rollout (after completion of pilot)

14. Technical and Operational Challenges

14.1 Performance and Latency Constraints

PQC algorithms impose performance characteristics different from classical cryptography:

Key Size Impact:

- ML-KEM-768: 1,184-byte public key vs ECDH 65 bytes (18x larger)
- ML-DSA-65: 1,312-byte public key + 2,420-byte signature vs ECDSA 65+64 bytes (40-50x larger)
- TLS handshake size increases 15-20x

Latency Impact:

- For most systems: <1% latency increase (sub-millisecond impact)
- For latency-sensitive systems (trading, gaming, real-time control): Potentially measurable impact
- CDN and edge network performance: Multiple additional round trips in some architectures

Mitigation Strategies:

- Hybrid cryptography: Use efficient hybrid constructions (e.g., X25519MLKEM768 combining ECDH and ML-KEM)
- Caching: Cache handshake results to amortize setup overhead
- Connection pooling: Reuse TLS connections to reduce handshake frequency
- Optimization: Use algorithm optimizations (vector instructions, hardware acceleration)

14.2 Network and Storage Overhead

Larger cryptographic artifacts require more storage and network bandwidth:

Storage Impact:

- Certificates: 2-3x larger (1-2 KB vs 200-500 bytes for classical)
- Certificate Revocation Lists (CRLs): Grow proportionally to certificate size
- Audit logs: More bytes logged for cryptographic operations
- Key management databases: Larger key storage

Network Impact:

- TLS handshake bandwidth: 15-30x overhead (typically <10 KB vs <1 KB for classical)
- API request/response sizes: Marginal impact (digital signatures in API responses)
- Database replication: Slightly larger payloads

Cumulative Impact for Large-Scale Operations:

- For internet scale (billions of TLS connections): Material bandwidth increase (tens of gigabits/second globally)
- For CDNs: Measurable increase in compute costs and latency

Mitigation:

- Graduated deployment: Phase migration to amortize impact
- Compression: TLS record compression to offset size increase
- Selective deployment: Use PQC only for high-risk data initially, expand later
- Capacity planning: Increase bandwidth capacity proactively

14.3 PKI Transformation and Certificate Management

Public Key Infrastructure transformation is one of the most complex aspects of PQC migration:

Challenges:

1. **Root CA Certificates:** Root CA certificates are used for decades and are difficult to change
 - Options: Parallel root CAs (maintain classical root alongside PQC root), composite roots (single cert with both algorithms), cross-signing
 - Complex implementation and operational procedures
2. **Intermediate CA Certificates:** Intermediate CAs bridge root CAs to end-entity certificates
 - Multiple options for hybrid deployment (classical chain with PQC leaf, hybrid intermediate, etc.)
 - Performance implications of each approach
3. **End-Entity Certificates:** Most frequently issued certificates
 - Relative ease of updating to PQC (shorter lifespans, simpler policies)
 - Interoperability with clients supporting classical or hybrid only

4. **Certificate Size Growth:** Larger certificates impact:
 - TLS extension limits (some systems have hard limits on extension sizes)
 - Certificate transparency logs (log size increases)
 - Client certificate storage
5. **Certificate Revocation:** OCSP and CRL mechanisms must handle larger certificates
 - Larger responses impact network traffic and client latency
 - OCSP responder performance

Migration Strategies:

1. **Hybrid Certificates:** Single certificate containing both classical and PQC keys and signatures
 - Advantage: Single certificate per entity
 - Disadvantage: Very large certificates, complex specification
2. **Parallel Certificate Chains:** Multiple certificates for same entity (one classical, one PQC)
 - Advantage: Cleaner separation, smaller certificates
 - Disadvantage: More complex client-server negotiation
3. **Composite Certificates:** Certificates with multiple signature algorithms (classical + PQC both signing)
 - Advantage: Highest security (attacker must compromise both)
 - Disadvantage: Very large, complex, slow verification
4. **Staged Transition:** Phase-in approach
 - Years 1-2: Hybrid certificates (classical + PQC)
 - Years 3-4: Parallel chains (legacy + PQC)
 - Years 5+: Pure PQC certificates

14.4 Legacy Systems and Embedded Devices

Some systems face particular difficulty transitioning to PQC:

Legacy Systems:

- Mainframe systems: May have cryptographic libraries tightly integrated with classical algorithms
- Windows/Linux systems: Support for PQC in newer OS versions; older systems may lack support
- Custom applications: Applications with embedded cryptographic implementations may require significant re-engineering

Embedded Devices:

- IoT devices: Constrained memory and processing power
- Smart cards: Very limited memory (typical smart card: <100 KB usable memory)
- Hardware tokens: Firmware update requirements
- Wireless sensors: Battery-powered, require efficient algorithms

Mitigation:

- Hybrid certificates and backward-compatible protocols
- Algorithm selection for constrained environments (e.g., optimized ML-KEM for IoT)
- Phased replacement: Retire old devices over time as newer devices support PQC
- Bridge solutions: Proxy servers or gateways supporting both classical and PQC

14.5 Supply Chain and Vendor Readiness

External dependencies create coordination challenges:

Vendor Support: - Cloud providers (AWS, Azure, Google): Support for PQC is rolling out in 2024-2025 but not complete - Cryptographic libraries (OpenSSL, Bouncy Castle, BoringSSL): Ongoing support additions - HSM vendors (Thales, Entrust, Utimaco): Firmware updates required for PQC support - Application vendors: Many commercial applications have no PQC support timeline

Third-Party Integration: - Customers may not support PQC, forcing fallback to classical cryptography - Vendors may phase out support slowly, creating long transition periods - APIs and protocols may require upgrade in coordination

Global Supply Chain ^{48, 49}: - Some countries restrict cryptography exports, potentially affecting international deployments - China, Russia, EU, US each have different perspectives on approved algorithms

15. Regulatory and Legal Implications

15.1 Post-Quantum Cryptography as “State of the Art”

Regulatory frameworks increasingly mandate “state-of-the-art” security measures, implicitly requiring PQC adoption:

GDPR (General Data Protection Regulation): - Article 32 requires “appropriate technical and organizational measures” including encryption - GDPR recital 83 references adopting “measures taking into account the state of the art” - UK ICO guidance: “consider identifying and addressing quantum risks as part of existing legal obligations” ⁵⁰ - GDPR fines: Up to €20 million or 4% of

⁴⁸ Sonatype. (2024, September 30). “State of the Software Supply Chain Report | 10 Year Look.” Retrieved from <https://www.sonatype.com/state-of-the-software-supply-chain/2024/10-year-look>

⁴⁹ PKI India. (2024). “Transition from Classical to Quantum Paradigm: PKI Challenges.” *Conference presentation*. Retrieved from <https://pkiindia.in/pkia/presentation/PKI%20Goutam%20Paul.pdf>

⁵⁰ Information Commissioner’s Office (ICO UK). (2024). “Guidance on Encryption and Quantum-Safe Security.” *ICO Technical Guidance Series*.

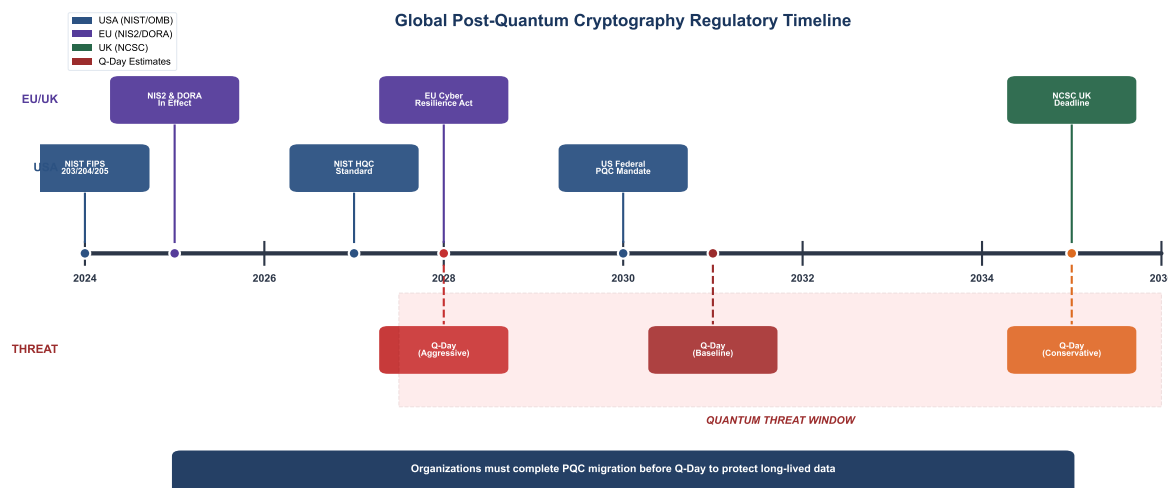


Figure 7: Global regulatory timeline for post-quantum cryptography adoption, showing key milestones from NIST standardization through national mandates (USA 2030, UK 2035), aligned with Q-Day threat estimates.

annual global turnover⁵¹

NIS2 Directive (Directive (EU) 2022/2555)⁵²: - In effect October 2024 - Article 21 requires “cryptographic practices” aligned with “state of the art” - Implementing Regulation (EU) 2024/2690 specifies PQC considerations - Applies to critical infrastructure, essential services, important entities

DORA (Digital Operational Resilience Act)⁵³:

- In effect January 2025
- Applies to financial institutions, insurers, payment firms, ICT suppliers
- Requires “robust cryptographic controls” tested and updated
- Specifically contemplates quantum threats

15.2 GDPR and Long-Term Confidentiality Obligations

GDPR imposes specific obligations for long-term data protection:

Confidentiality Obligations:

⁵¹ European Parliament and Council. (2016). “Regulation (EU) 2016/679 of the European Parliament and of the Council (General Data Protection Regulation).” *Official Journal of the European Union*, L 119/1.

⁵² European Parliament and Council. (2022). “Directive (EU) 2022/2555 on measures for a high common level of cybersecurity across the Union (NIS2 Directive).” *Official Journal of the European Union*, L 333/80.

⁵³ European Parliament and Council. (2022). “Regulation (EU) 2022/2554 on digital operational resilience for the financial sector (DORA).” *Official Journal of the European Union*, L 333/1.

- Data controllers must ensure confidentiality of personal data for the “retention period”
- Retention periods extend from 3 years (some tax records) to indefinite (some healthcare data, trade secrets)
- Confidentiality obligation extends throughout retention period

Quantum Risk Implications:

- Data encrypted today with classical cryptography faces quantum decryption risk during retention period
- Failure to migrate to PQC during retention period could constitute breach of “appropriate security measures”
- Regulator enforcement action could allege negligence in failing to adopt “state of the art” PQC

GDPR Compliance Action Required:

- Organizations should conduct Data Protection Impact Assessments (DPIAs) addressing quantum threats
- Organizations should incorporate quantum-safe migration into cryptographic policies
- Organizations should document risk assessment and mitigation strategy

15.3 NIS2, DORA, and Cyber Resilience Act

European regulatory framework increasingly incorporates quantum-specific requirements:

NIS2 Cryptographic Requirements:

- Cryptographic policies based on “state of the art”
- Cryptographic agility mechanisms enabling rapid algorithm changes
- Key management procedures and lifecycle
- Annual cryptographic policy reviews

DORA Specific Requirements:

- Robust cryptographic controls for financial services
- Continuous testing of cryptographic implementations
- Incident reporting for cryptographic failures

EU Cyber Resilience Act (emerging):

- Broad requirements for security in digital products and services
- Implicit requirements for quantum-safe cryptography
- Enforcement by EU member states

National Mandates^{54, 55}:

- **UK:** NCSC mandates PQC migration by 2035
- **US:** Federal mandate (OMB, NSM-10, HR 7535) requires PQC by 2030-2035
- **Germany:** BSI recommends PQC adoption by 2025-2030
- **Netherlands, Austria, and other EU members:** Equivalent requirements

15.4 Liability Risks of Delayed Migration

Organizations delaying PQC migration face increasing liability risks:

Regulatory Liability:

- GDPR enforcement actions for inadequate “state of the art” encryption
- Fines for confidentiality breaches attributable to delayed PQC migration
- Mandatory security audits and breach notifications

Litigation Risk⁵⁶:

- Shareholder litigation if breaches occur from known quantum risks
- Customer class-action litigation for privacy violations
- Third-party litigation (e.g., hospitals for medical data breaches)

Reputational Risk:

- Public disclosure of quantum-related breaches causes severe reputational damage
- Loss of customer trust
- Media coverage and public perception of recklessness

Insurance Risk:

- Cyber insurance may exclude breaches from known quantum threats
- Coverage may be denied if organization failed to adopt industry-standard PQC
- Future insurance may be unavailable for organizations with quantum breach history

⁵⁴ UK National Cyber Security Centre (NCSC). (2024). “Next Steps in Preparing for Post-Quantum Cryptography.” *White Paper*. Retrieved from <https://www.ncsc.gov.uk/whitepaper/next-steps-preparing-for-post-quantum-cryptography>

⁵⁵ Office of Management and Budget (OMB). (2023). “Memorandum M-23-02: Migrating to Post-Quantum Cryptography.” *U.S. Government Memorandum*.

⁵⁶ U.S. Securities and Exchange Commission. (2023, September 3). “Post-Quantum Financial Infrastructure Framework (PQFIF).” *Written input to CFT*. Retrieved from <https://www.sec.gov/files/cft-written-input-daniel-bruno-corvelo-costa-090325.pdf>

16. Strategic and Economic Considerations

16.1 Cost of Migration vs Cost of Breach

PQC migration requires upfront investment, but quantum breach costs are substantially higher:

Migration Costs:

- Cryptographic inventory and assessment: \$100K-\$500K (one-time)
- Tool acquisition (CBOM tools, certificate management): \$500K-\$2M (one-time)
- Software development (crypto-agility, algorithm updates): \$1M-\$5M+ (one-time, varies by org size)
- Hardware updates (HSMs, servers): \$500K-\$2M+ (one-time)
- Personnel and training: \$200K-\$1M+ (ongoing)
- Operational procedures and automation: \$500K-\$1M+ (one-time)

Total Migration Cost Estimate:

- Small organization (100s of systems): \$2-5M over 2 years
- Medium organization (1000s of systems): \$5-20M over 3 years
- Large organization (10000s of systems): \$20-100M+ over 3-5 years

Quantum Breach Costs (if delayed and quantum attack occurs) ^{57, 58, 59}:

- Detection and forensics: \$500K-\$1M
- Notification and remediation: \$1-10M (scales with data volume)
- Regulatory fines: €10-20M (GDPR maximum) or percentage of revenue ⁶⁰
- Litigation costs: \$1-50M+ (scales with impact)
- Reputational damage: \$10-100M+ (customer churn, stock price impact)

Total Breach Cost Estimate ^{61, 62}:

⁵⁷ IBM Security. (2025). “Cost of a Data Breach Report 2025.” Retrieved from <https://www.ibm.com/reports/data-breach>

⁵⁸ Ponemon Institute. (2024). “Cost of a Data Breach Report 2024.” *IBM Security / Ponemon Institute*. Available: <https://www.ibm.com/security/data-breach>

⁵⁹ Verizon. (2024). “2024 Data Breach Investigations Report.” *Verizon Business*. Available: <https://www.verizon.com/business/resources/reports/dbir/>

⁶⁰ Aon & DLA Piper. (2018, May). “The Price of Data Security: GDPR Fines and Penalties Guide.” Retrieved from https://www.aon.com/attachments/risk-services/Aon_DLA-Piper-GDPR-Fines-Guide_Final_May2018.pdf

⁶¹ Fortra. (2022, June 23). “The Cost and Consequences of Exposed PII.” Retrieved from <https://www.fortra.com/blog/the-cost-and-consequences-of-exposed-pii>

⁶² Ponemon Institute. (2024). “Cost of a Data Breach Report 2024.” *IBM Security / Ponemon Institute*. Available: <https://www.ibm.com/security/data-breach>

- If long-lived data is affected: \$20-200M+ (healthcare, government, finance)
- If quantum attack affects multiple organizations (e.g., cloud provider compromise): \$100M-\$1B+ (aggregate)

Economic Analysis:

- Expected cost = (probability of quantum decryption × breach cost) + migration cost
- Probability of quantum decryption for long-lived data: 60-100% under baseline Q-Day assumptions
- Expected value of delay: -\$10M to -\$100M+ (cost of delay exceeds cost of migration)
- Recommendation: Migrate now

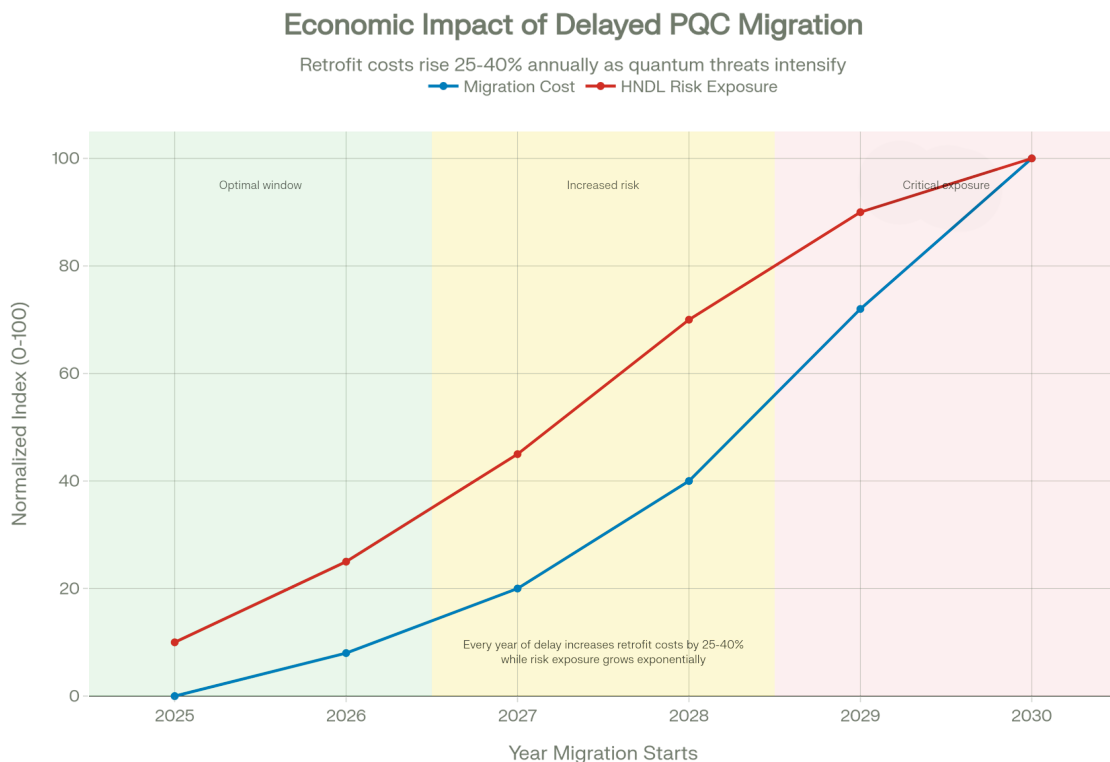


Figure 8: Cost comparison between proactive PQC migration versus reactive quantum breach response, demonstrating the exponentially increasing costs of delayed migration relative to Q-Day timeline.

16.2 National Security and Economic Stability

Quantum cryptanalysis has national security implications:

Geopolitical Intelligence:

- HNDL attacks enable retroactive decryption of decades of strategic communications
- Governments conducting HNDL attacks gain decades of intelligence advantage
- Strategic advantage accrues to first nation to deploy CRQC

Critical Infrastructure:

- Compromise of critical infrastructure cryptography enables sabotage
- Power grids, water systems, transportation networks vulnerable to quantum-enabled attacks
- National security implications of quantum decryption of critical infrastructure commands

Economic Stability:

- Financial system reliance on cryptography for settlement, trading, custody
- Quantum compromise could undermine trust in financial systems
- Economic impact of financial system disruption: trillions of dollars globally

National Response:

- Governments are prioritizing PQC migration for critical infrastructure and defense
- International coordination on quantum-safe standards (NIST, ISO, ETSI)
- Export controls on quantum computers and cryptographic capabilities

16.3 Timeline Risk and Organizational Inertia

Organizations face risk from delayed migration:

Timeline Risk^{63, 64}:

- If Q-Day occurs before PQC migration is complete, exposed data becomes vulnerable immediately
- Organizations migrating later face accelerated timelines, increased costs, and error risk
- Historical example: Y2K crisis (1999-2000)—organizations that delayed faced crisis-driven hasty implementations⁶⁵

Organizational Inertia:

- Cryptographic changes require coordination across many teams
- Legacy systems are difficult to change
- Competing priorities limit resources available for PQC
- Organizational inertia slows response despite urgency

Mitigation:

- Board-level governance establishing quantum risk as enterprise priority
- Dedicated resources and budget for PQC program
- Vendor and third-party engagement to ensure supply chain readiness

⁶³ ScienceDirect. (2025). “Complexity and the Transition to Post-Quantum Security.” *Procedia Computer Science*. Retrieved from <https://www.sciencedirect.com/science/article/pii/S1877050925022896>

⁶⁴ McKinsey & Company. (2023). “Quantum Computing: An Emerging Ecosystem and Industry Use Cases.” *McKinsey Global Institute Report*.

⁶⁵ Jones, C. (2000). “Software Assessments, Benchmarks, and Best Practices.” *Addison-Wesley Professional*. ISBN: 0-201-48542-7

- Regular reporting on PQC migration progress
-

17. Discussion

17.1 Integrating Threat Models with Migration Strategy

This research integrates the formal HNDL threat model with practical migration frameworks:

Key Insight: The fundamental vulnerability condition ($L_d > H_a$) maps directly to organizational data inventory and retention policies. Organizations can operationalize quantum risk assessment by:

1. Identifying data with $L_d > H_a$ (vulnerable data)
2. Prioritizing migration resources toward systems protecting vulnerable data
3. Tracking progress toward complete migration by deadline

Implications for Practice:

- Organizations managing long-lived data (healthcare, finance, government) face near-certain HNDL exposure under baseline Q-Day assumptions
- Organizations delaying migration face exponentially increasing costs as Q-Day approaches
- Migration must begin immediately to enable orderly transition

17.2 Why Waiting for Q-Day Is a Critical Error

Several factors make waiting for Q-Day appearance a strategic error:

1. **Cryptographic Transition Duration:** Moving entire cryptographic infrastructure to PQC requires 2-5 years for most organizations
2. **Supply Chain Coordination:** Vendors, cloud providers, and partners must coordinate transition (adds 1-3 years)
3. **Legacy System Constraints:** Some systems are difficult to upgrade and require extended transition periods
4. **Data Confidentiality Requirements:** Data encrypted today remains sensitive throughout cryptographic transition period

Timeline Analysis: - Q-Day estimate: 2030 ± 5 years (accounting for uncertainty) - Migration duration: 2-5 years after decision - Required migration start: 2025-2028 (to complete before 2030-2035) - Current date: 2024-2025

Implication: Organizations should begin PQC migration now. Waiting until Q-Day appears imminent creates crisis-driven implementations prone to error and disruption.

17.3 Limitations of Current Research

This research has several limitations:

1. **Q-Day Uncertainty:** Timeline estimates remain uncertain despite recent convergence. Conservative estimates (2035-2040) would extend timelines, while aggressive estimates (2027-2028) would compress them.
 2. **Algorithm Risk:** While NIST standardization provides strong confidence in PQC algorithms, all cryptographic systems carry residual risk. Unknown quantum algorithms or cryptanalytic breakthroughs could change risk profiles.
 3. **Implementation Risk:** Security of PQC systems depends on correct implementation. Side-channel attacks, implementation bugs, and operational misuse could compromise theoretical security.
 4. **Geopolitical Uncertainty:** National restrictions on quantum technology, cryptography, or specific algorithms could affect deployment timelines and options.
 5. **Technology Uncertainty:** Alternative paradigms (quantum computing hardware advances, quantum repeaters enabling QKD, or entirely new approaches) could change threat profiles.
-

18. Future Research Directions

18.1 Continuous Cryptanalysis of PQC Algorithms

Ongoing cryptanalysis remains critical:

- **Lattice-based cryptanalysis:** Improved lattice reduction algorithms or quantum algorithms could threaten lattice-based schemes
- **Code-based cryptanalysis:** Advances in decoding algorithms could threaten code-based schemes
- **Implementation analysis:** Side-channel analysis of PQC implementations to identify vulnerable implementations
- **Post-standardization research:** NIST expects that HQC and other candidates will provide diversity should primary standards weaken

18.2 Automated Cryptographic Discovery Tools

Better tools for cryptographic inventory would accelerate migration:

- **AI-driven discovery:** Machine learning models to identify cryptographic artifacts with high accuracy and low false positive rates
- **Continuous monitoring:** Real-time identification of new cryptographic systems and algorithm changes

- **Integration with existing tools:** Cryptographic discovery integrated with vulnerability management, asset management, and SIEM tools ⁶⁶
- **Supply chain visibility:** Better mechanisms to track cryptographic dependencies through supply chains ⁶⁷

18.3 Post-Quantum Security for IoT and Embedded Systems

Constrained environments require specialized solutions:

- **Lightweight PQC algorithms:** Algorithms optimized for IoT devices with minimal memory and power
- **Hardware acceleration:** Specialized hardware for PQC operations in embedded systems
- **Hybrid lightweight schemes:** Combinations of classical and PQC optimized for constrained environments
- **Secure enclaves:** TEE-based approaches for cryptographic operations on constrained devices

18.4 International Standard Harmonization

Global coordination on PQC standards would reduce fragmentation:

- **Algorithm standardization:** Additional standards beyond NIST (ISO, ETSI) to enable global deployment ^{68, 69}
- **Protocol standardization:** TLS, IPsec, SSH, and other protocols updated to support PQC consistently
- **Regulatory harmonization:** Countries aligning on PQC requirements and timelines
- **Export control harmonization:** Reducing barriers to international PQC deployment

⁶⁶ IBM. (2025, July 24). “What Is the Software Development Lifecycle (SDLC)?” Retrieved from <https://www.ibm.com/think/topics/sdlc>

⁶⁷ Sonatype. (2024, September 30). “State of the Software Supply Chain Report | 10 Year Look.” Retrieved from <https://www.sonatype.com/state-of-the-software-supply-chain/2024/10-year-look>

⁶⁸ European Telecommunications Standards Institute (ETSI). (2024). “Quantum-Safe Cryptography Standards.” *ETSI Technical Committee CYBER*. Available: <https://www.etsi.org/committee/cyber>

⁶⁹ International Organization for Standardization (ISO). (2024). “ISO/IEC 23837: Information security — Security requirements, test and evaluation methods for quantum key distribution.” *ISO/IEC JTC 1/SC 27*.

19. Conclusion

19.1 Summary of Findings

This research establishes:

1. **HNDL is a present-day threat:** Adversaries are actively harvesting encrypted data today with the intent to decrypt it using future quantum computers^{70, 71}. This creates a present-day imperative despite quantum computers remaining years away.
2. **Quantum timeline is credible:** Recent research has compressed Q-Day estimates from decades to approximately 2030 ± 5 years^{72, 73}, with baseline consensus suggesting late 2020s or early 2030s.
3. **Long-lived data faces near-certain exposure:** Data encrypted today using RSA or ECC faces near-certain retroactive decryption risk if quantum computers emerge within historical retention periods for that data.
4. **PQC standards are ready:** NIST finalized ML-KEM, ML-DSA, and SLH-DSA standards in August 2024, providing validated, implementable alternatives to classical cryptography^{74, 75}.
5. **Migration must begin immediately:** Effective migration requires 2-5 years for most organizations. To complete before Q-Day, migration should begin in 2025-2026.
6. **Hybrid approaches provide transition path:** Combining classical and PQC cryptography enables gradual transition while maintaining security guarantees.

⁷⁰ National Security Agency (NSA). (2022). “Quantum Computing and Post-Quantum Cryptography.” *NSA Cybersecurity Information Sheet*. Available: <https://www.nsa.gov/Cybersecurity/Post-Quantum-Cybersecurity-Resources/>

⁷¹ Federal Reserve Board. (2025). “Harvest Now Decrypt Later: Examining Post-Quantum Cryptography Risk in Financial Services.” *Finance and Economics Discussion Series 2025-093*. Retrieved from <https://www.federalreserve.gov/econres/feds/files/2025093pap.pdf>

⁷² Gidney, C., & Ekerå, M. (2019). “How to factor 2048 bit RSA integers in 8 hours using 20 million noisy qubits.” *Quantum*, 5, 433. DOI: 10.22331/q-2021-04-15-433

⁷³ National Security Agency (NSA). (2022). “Quantum Computing and Post-Quantum Cryptography.” *NSA Cybersecurity Information Sheet*. Available: <https://www.nsa.gov/Cybersecurity/Post-Quantum-Cybersecurity-Resources/>

⁷⁴ National Institute of Standards and Technology (NIST). (2024). “Post-Quantum Cryptography Standardization.” Retrieved from <https://csrc.nist.gov/projects/post-quantum-cryptography>

⁷⁵ National Institute of Standards and Technology (NIST). (2024, August). “NIST Releases First 3 Finalized Post-Quantum Encryption Standards.” *NIST News*. Retrieved from <https://www.nist.gov/news-events/news/2024/08/nist-releases-first-3-finalized-post-quantum-encryption-standards>

7. **Regulatory pressure is increasing:** GDPR, NIS2, DORA, and national mandates are encoding PQC requirements into compliance frameworks^{76, 77}, creating both incentives and penalties for migration.
8. **Economic case is compelling:** Migration costs are orders of magnitude smaller than potential breach costs if long-lived data is compromised.

19.2 Implications for Industry and Government

For Organizations: - Treat PQC migration as a strategic enterprise priority, not a technical niche issue - Establish board-level governance and dedicated resources - Begin cryptographic inventory and risk assessment in 2025 - Pilot PQC deployment in 2025-2026 - Achieve 50%+ migration by 2028 - Target 90%+ migration by 2030-2032

For Cloud Providers and Technology Vendors: - Accelerate PQC support across all services and APIs - Provide migration tools and guidance to customers - Ensure third-party dependencies support PQC - Coordinate with other vendors and standards bodies

For Government and Regulators^{78, 79}: - Establish clear timelines and requirements for PQC adoption - Provide guidance and standards (NIST, NCSC, ENISA models) - Consider regulatory enforcement to ensure migration progress - Coordinate internationally on quantum-safe standards

For Researchers: - Continue cryptanalysis of PQC algorithms - Develop tools for automated cryptographic discovery and management - Research PQC for constrained environments (IoT, embedded) - Investigate alternative quantum-secure paradigms

19.3 Final Statement

The quantum threat is not a future event—it is a present-day risk to long-lived data.

Organizations managing data with confidentiality requirements extending years or decades face a strategic imperative to migrate to post-quantum cryptography now. Waiting for quantum computers to appear before beginning migration creates unnecessary risk, cost, and disruption.

⁷⁶ European Union Agency for Cybersecurity (ENISA). (2024). “Post-Quantum Cryptography: Current State and Quantum Mitigation.” *ENISA Report*. Available: <https://www.enisa.europa.eu/publications/post-quantum-cryptography-current-state-and-quantum-mitigation>

⁷⁷ European Telecommunications Standards Institute (ETSI). (2023). “Migration Strategies and Recommendations for Quantum-Safe Schemes.” *ETSI Technical Report TR 103 823*. Available: https://www.etsi.org/deliver/etsi_tr/103800_103899/103823/

⁷⁸ Office of Management and Budget (OMB). (2023). “Memorandum M-23-02: Migrating to Post-Quantum Cryptography.” *U.S. Government Memorandum*.

⁷⁹ UK National Cyber Security Centre (NCSC). (2024). “Next Steps in Preparing for Post-Quantum Cryptography.” *White Paper*. Retrieved from <https://www.ncsc.gov.uk/whitepaper/next-steps-preparing-for-post-quantum-cryptography>

The convergence of quantum computing progress, regulatory mandates, cryptographic standards, and economic incentives creates a clear business case for immediate action.

The window for orderly transition is now. The tools, standards, and expertise are available. What remains is organizational commitment and execution. The consequences of failure—mass privacy violation, geopolitical intelligence compromise, financial system disruption, loss of public trust—justify the investment required for migration.

Harvest Now, Decrypt Later attacks are not hypothetical. They are active today. The data encrypted in 2024-2025 using classical cryptography will be vulnerable to retroactive decryption within a decade if migration to post-quantum cryptography is not completed. Organizations must act now to protect their data, their customers, and their operations in the quantum era.

Appendix

Mathematical Notation

Notation	Definition
Ld	Data confidentiality lifetime; the duration for which encrypted data must remain confidential from time of encryption until obsolescence or regulatory expiration
Ha	Attacker decryption horizon; the estimated calendar date at which adversaries obtain practical capability to decrypt classical public-key cryptography
T_qday	“Q-Day”; the estimated date at which cryptographically-relevant quantum computers become operationally feasible
P(X)	Probability of event X
RSA-n	RSA public-key encryption using an n-bit modulus (e.g., RSA-2048)
ECC-p	Elliptic curve cryptography defined over a finite field of size p bits
Shor(N)	Shor’s quantum algorithm for integer factorization of N
Grover(f)	Grover’s quantum search algorithm for preimage search of function f
ML-KEM	Module-Lattice-Based Key-Encapsulation Mechanism (NIST FIPS 203)
ML-DSA	Module-Lattice-Based Digital Signature Algorithm (NIST FIPS 204)
SLH-DSA	Stateless Hash-Based Digital Signature Algorithm (NIST FIPS 205)

Notation	Definition
HNDL	Harvest Now, Decrypt Later attack model involving deferred cryptographic decryption

HNDL Model Extensions

Extension 1: Multi-Party Risk Aggregation

For organizations managing multiple data types with different confidentiality lifetimes:

$$\text{Risk}_{\text{org}} = \sum_{i=1}^n P(L_d^{(i)} > H_a \mid \text{data_type}_i) \times (\text{data_value}_i \times \text{impact}_i)$$

Where aggregation sums risk across all data types.

Extension 2: Supply Chain Propagation

For organizations with supply chain dependencies:

$$\begin{aligned} \text{Risk}_{\text{customer}} = & \text{Risk}_{\text{direct}} + \text{Risk}_{\text{vendor}_1} \times P(\text{vendor}_1_{\text{compromise}}) \\ & + \text{Risk}_{\text{vendor}_2} \times P(\text{vendor}_2_{\text{compromise}}) + \dots \end{aligned}$$

Demonstrates how supply chain risks propagate.

Extension 3: Probabilistic Timeline Modeling

For modeling uncertainty in Q-Day:

$$\begin{aligned} P(\text{decrypt} \mid \text{data}, t) = & P(H_a \leq t) \times P(L_d \geq t \mid \text{data_type}) \\ & \times P(\text{attacker_targets} \mid \text{threat_actor}) \end{aligned}$$

Enables scenario analysis across multiple Q-Day assumptions.

Supplementary Tables

Table A1: Quantum Algorithm Threat Timeline

Date	Quantum Capability	Impact on Cryptography	Mitigation Status
2024	~1000 logical qubits (research stage)	None; no cryptographic threat	Begin PQC migration

Date	Quantum Capability	Impact on Cryptography	Mitigation Status
2027-2028	~100-1000 logical qubits (small FT QC)	Potential early attacks on weak systems	Migration 20-30% complete
2030 (baseline)	~4000-10000 logical qubits (CRQC emerging)	RSA-2048, ECC vulnerable	Migration 50-80% complete
2032-2035	~10000+ logical qubits (CRQC mature)	All classical algorithms vulnerable	Migration 95%+ complete, HNDL decryption begins
2040+	Quantum computers ubiquitous	Classical cryptography completely obsolete	Pure PQC deployment universal

Table A2: Sector Migration Timeline Recommendations

Sector	Phase 1 Start	Phase 2 Complete	Phase 3 Deadline	Full Migration Target
Healthcare	Q1 2025	Q2 2026	Q4 2027	2029
Finance	Q1 2025	Q2 2026	Q4 2027	2029
Government	Q1 2025	Q4 2026	Q2 2028	2030
Cloud Providers	Q1 2025	Q2 2026	Q4 2027	2029
Critical Infrastructure	Q2 2025	Q1 2027	Q2 2028	2030
Technology	Q2 2025	Q3 2026	Q2 2028	2029

Table A3: Cost Estimates by Organization Size

Org Size	Systems	CBOM/Assessment	Tools	Development	Hardware	Personnel	Total 2-Year Cost
Small (100 systems)	100	\$100K	\$200K	\$500K	\$100K	\$100K	\$1M
Medium (1000 systems)	1000	\$200K	\$500K	\$2M	\$500K	\$300K	\$3.5M
Large (10000 systems)	10000	\$500K	\$1.5M	\$5M	\$2M	\$1M	\$10M
Enterprise (100000+ systems)	100000	\$1M	\$3M	\$10M	\$5M	\$2M	\$21M

Acknowledgments

This research draws upon publicly available technical documentation, standards publications, and advisory materials from the National Institute of Standards and Technology (NIST), Cybersecurity and Infrastructure Security Agency (CISA), National Security Agency (NSA), and the UK National Cyber Security Centre (NCSC).

Additional insights were derived from publicly disclosed deployment experiences and technical publications from industry organizations including Apple, Google, Cloudflare, IBM, and Amazon Web Services (AWS).

The author further acknowledges the broader global cryptographic research community whose foundational work in post-quantum cryptography, algorithm design, security analysis, and standardization efforts has made this research possible.

Disclaimer

This document represents a synthesis of publicly available research, standards documentation, and technical analysis available as of January 2026. Cryptographic recommendations and guidance contained herein should be independently validated against the most current NIST FIPS publications, vendor documentation, and applicable organizational security requirements prior to implementation.

The author assumes no responsibility or liability for any operational, security, financial, regulatory, or compliance outcomes arising from the use of, or reliance upon, this material.